Governance von Künstlicher Intelligenz: Eine vergleichende Analyse bestehender Modelle zur Gestaltung unternehmensinterner KI-Steuerung

Seminararbeit
im Studiengang IT-Management
der Universität Münster Professional School

vorgelegt von
Nick Ansgar Stelzer
Email: nick.stelzer@saria.com

Themensteller:	Prof. Dr. Dr. h.c. Becker
Ausgabedatum:	02.07.2025
Abgabedatum:	27.08.2025

Inhaltsverzeichnis

Abkürzungsverzeichnis **III**

1 Einleitung **1**

2 Grundlagen der AI-Governance **2**
2.1 Künstliche Intelligenz 2
2.2 IT-Governance als konzeptionelle Grundlage 2
2.3 Definition und Verständnis von AI-Governance 3
2.4 Abgrenzung zu verwandten Konzepten 3
2.5 Normative Rahmenwerke 4

3 Vorstellung & Analyse ausgewählter Modelle der AI-Governance **6**
3.1 ISO/IEC 42001 6
3.2 EU-AI-Act 8
3.3 NIST AI Risk Management Framework 11
3.4 Multilevel-AI-Governance-Framework 13
3.5 Hourglass Model of Organizational AI Governance 14

4 Vergleich und Bewertung (Matrix) **17**
4.1 Bewertungslogik und Datengrundlage 17
4.2 Kriterienkatalog 17
4.3 Scoring- und Gewichtungsschema 18
4.4 Einbindung der Experteninterviews in die Gesamtgewichtung . 18
4.5 Darstellung der Ergebnisse 21
4.6 Gesamtbewertung der Modelle (K1–K12) 27

5 Reflexion **28**
5.1 Auswertung der Matrix 28
5.2 Einordnung anhand der Interviewperspektiven 29
5.3 Aussagekraft und Grenzen der Bewertung 29
5.4 Übertragbarkeit und Kontextabhängigkeit 30

6 Empfehlungen für die Gestaltung von AI-Governance **31**
6.1 Begründung der Kombination 31
6.2 Stärken, Schwächen und Abdeckung 31
6.3 Praktische Grundstruktur mit technischem und organisatorischem Fokus 32
6.4 Erweiterbarkeit um ISO/IEC 42001 und Multilevel Framework . 32

6.5 Hinweise zur Umsetzungstiefe 32

7 Fazit und Ausblick 34

7.1 Fazit 34

7.2 Beitrag der Arbeit 34

7.3 Grenzen 34

7.4 Ausblick 35

A Appendix 37

B Interviews 37

B.1 Interviewleitfaden 37

B.2 Interview 1 (CIO, via Teams) 40

B.3 Interview 2 (Head of IT-Security, vor Ort) 48

B.4 Interview 3 (Datenschutzbeauftragter, vor Ort) 59

Literaturverzeichnis 73

Abkürzungsverzeichnis

AI Artifical Intelligence 1
AIMS AI Management System 7
DSGVO Datenschutzgrundverordnung 21
FDA Food and Drug Administration 13
GPAI General-Purpose AI 9
IEC International Electrotechnical Commission 6
IP Intellectual Property 38
ISO International Organization for Standardization 6
KI Künstliche Intelligenz 1
KMU kleine und mittlere Unternehmen 10
NIST National Institute of Standards and Technology 2

Die in dieser Arbeit erwähnten Unternehmens-, Produkt- oder Markenbezeichnungen können Marken oder eingetragene Markenzeichen der jeweiligen Eigentümer sein. Die Wiedergabe von Marken- und/oder Warenzeichen in dieser Arbeit berechtigt nicht zu der Annahme, dass diese als frei von Rechten Dritter zu betrachten seien. Alle erwähnten Marken- und/oder Warenzeichen unterliegen uneingeschränkt den länderspezifischen Schutzbestimmungen und den Besitzrechten der jeweiligen eingetragenen Eigentümer.

1 Einleitung

Die zunehmende Verbreitung und Leistungsfähigkeit von Anwendungen der künstlichen Intelligenz (KI) stellt Unternehmen vor erhebliche Chancen, aber auch neue Herausforderungen. Einerseits eröffnen Künstliche Intelligenz (KI)-Systeme Potenziale zur Automatisierung, Effizienzsteigerung und datenbasierten Entscheidungsfindung.[1] Andererseits sind sie mit Risiken verbunden, die von mangelnder Transparenz („Black-Box"-Problematik) über Verzerrungen in den Daten bis hin zu ethischen und regulatorischen Fragen reichen.[2]

Während sich in den vergangenen Jahren umfangreiche Literatur zu IT-Governance und Data Governance entwickelt hat[3][4], ist das Feld der Artifical Intelligence (AI)-Governance noch vergleichsweise jung und heterogen. Unterschiedliche Modelle und Frameworks konkurrieren um Geltung, wobei bislang ein einheitlicher Ansatz für den organisationalen Umgang mit KI fehlt.[5][6] Besonders für Unternehmen stellt sich die Frage, welche Strukturen, Rollen und Mechanismen geeignet sind, um den sicheren, regelkonformen und zugleich innovationsfördernden Einsatz von KI-Systemen zu gewährleisten.[7]

Vor diesem Hintergrund verfolgt die vorliegende Seminararbeit das Ziel, bestehende Konzepte und Modelle der AI-Governance systematisch aufzuarbeiten und vergleichend zu analysieren. Das Forschungsziel besteht darin, auf Basis dieser Analyse sowie ergänzender Experteninterviews Anforderungen und Gestaltungsoptionen für die unternehmensinterne Steuerung von KI abzuleiten. Damit soll die Arbeit nicht nur einen Beitrag zur theoretischen Fundierung, sondern auch praxisorientierte Empfehlungen zur Ausgestaltung von AI-Governance liefern.

Die Arbeit gliedert sich in Grundlagen (Kap. 2), Modelle (Kap. 3), Vergleich/Bewertung inkl. Experteninterviews (Kap. 4), Reflexion (Kap. 5), Empfehlungen (Kap. 6) sowie Fazit und Ausblick (Kap. 7).

[1] Rai, Constantinides und Sarker 2019, S. 4, 7.
[2] EC 2025, S. 13, 14–17.
[3] Weill und Ross 2004, S. 8–10.
[4] Khatri und Brown 2010, S. 148.
[5] Batool, Zowghi und Bano 2023, S. 2–3.
[6] Mäntymäki u. a. 2025, S. 3–4.
[7] Choung, David und Seberger 2023, S. 2–4.

2 Grundlagen der AI-Governance

Die Diskussion um die Steuerung und Kontrolle von KI setzt zunächst eine begriffliche und konzeptionelle Klärung voraus. Dieses Kapitel legt die theoretischen Grundlagen, indem es zunächst zentrale Begriffe definiert (Abschnitt 2.1) und anschließend den Zusammenhang zwischen IT-Governance und AI-Governance erläutert (Abschnitt 2.2). Darauf aufbauend werden unterschiedliche Definitionen und Verständnisse von AI-Governance vorgestellt (Abschnitt 2.3), bevor eine Abgrenzung zu verwandten Konzepten wie Data Governance und AI Ethics erfolgt (Abschnitt 2.4). Abschließend werden normative Rahmenwerke skizziert, die für die Entwicklung und Umsetzung von AI-Governance relevant sind (Abschnitt 2.5).

2.1 Künstliche Intelligenz

In der Literatur gibt es unterschiedliche Definitionen für den Begriff Künstliche Intelligenz (KI). Rai, Constantinides und Sarker 2019, S. 3 definieren KI als „die Fähigkeit einer Maschine, kognitive Funktionen auszuführen, die wir mit dem menschlichen Geist verbinden, wie Wahrnehmung, Lernen, Problemlösung und Entscheidungsfindung.“ In ähnlicher Weise definiert das National Institute of Standards and Technology (NIST) in ihrem AI Risk Management Framework KI als ein technisches System, das Ergebnisse wie Vorhersagen, Empfehlungen oder Entscheidungen erzeugen kann, die reale oder virtuelle Umgebungen beeinflussen können.[8]
Diese Definitionen verdeutlichen, dass KI-Systeme nicht nur technische Werkzeuge sind, sondern tiefgreifende Auswirklungen auf gesellschaftliche Prozesse und Strukturen haben können. Daraus ergibt sich die Notwendigkeit einer gezielten Steuerung und Kontrolle, um sicherzustellen, dass sie im Einklang mit ethischen, rechtlichen und sozialen Standards entwickelt und eingesetzt werden.

2.2 IT-Governance als konzeptionelle Grundlage

AI-Governance knüpft an bestehende Governance-Ansätze an und baut insbesondere auf Konzepten der IT-Governance auf. Sie umfasst „die Spezifikation von Entscheidungsrechten und Rechenschaftsmechanismen, um sicherzustellen, dass die Nutzung von IT das Verhalten in Übereinstimmung mit den strategischen Zielen des Unternehmens fördert“.[9]

[8] National Institute of Standards and Technology 2025, S. 1.
[9] Weill und Ross 2004, S. 64.

Während sich IT-Governance auf Themen wie Investitionen, IT-Architektur oder Sicherheitsmanagement konzentriert, erweitert AI-Governance diesen Rahmen um ethische, regulatorische und gesellschaftliche Dimensionen.[10] Sie ist damit als Weiterentwicklung und Spezialisierung der IT-Governance zu verstehen, um den besonderen Herausforderungen und Risiken von KI-Systemen gerecht zu werden.

2.3 Definition und Verständnis von AI-Governance

Eine einheitliche Definition von AI-Governance existiert in der Literatur bislang nicht, es lassen sich jedoch einige zentrale Elemente identifizieren. Mäntymäki u. a. 2025, S. 2–3 definieren AI-Governance als ein System von Regeln, Praktiken, Prozessen und Technologien, die sicherstellt, dass der Einsatz von KI im Einklang mit den Werten und Zielen der Organisation sowie rechtlichen und ethischen Anforderungen steht.
Batool, Zowghi und Bano 2023, S. 2–3 betonen die Betrachtung des kompletten Lebenszyklus von KI-Systemen, von der Entwicklung über den Betrieb bis hin zur Außerbetriebnahme.
Dieser Blickwinkel wird durch Choung, David und Seberger 2023, S. 2–4 erweitert, indem sie AI-Governance als mehrstufiges Konzept verstehen, das auf individueller, organisationaler, nationaler und internationaler Ebene etabliert werden muss, um ein belastbares Vertrauen in KI-Systeme zu ermöglichen.
Damit lässt sich AI-Governance allgemein als ein interdisziplinäres Konzept verstehen, das technische, organisatorische, regulatorische und ethische Dimensionen miteinander verbindet.

2.4 Abgrenzung zu verwandten Konzepten

AI-Governance überschneidet sich mit anderen Disziplinen, unterscheidet sich aber durch ihren umfassenden Anspruch:

- **Data Governance:** Das Ziel der Data Governance ist die Sicherstellung von Datenqualität, -sicherheit und -verfügbarkeit. Khatri und Brown 2010, S. 148–149 definieren Data Governance als „decision rights and accountabilities for setting and enforcing data-related policies“. Damit bildet Data Governance eine notwendige Grundlage für AI-Governance aber diese ist nicht ausreichend um die spezifischen Herausforderungen adaptiver Systeme zu steuern.

[10] Choung, David und Seberger 2023, S. 2–4.

- **AI Ethics:** Ethische Leitlinien, wie etwa die *Ethics Guidelines for Trustworthy AI* der Europäischen Kommission, formulieren normative Prinzipien wie Fairness, Transparenz, Rechenschaftspflicht oder Nicht-Diskriminierung.[11] Diese stellen jedoch keinen organisatorischen Umsetzungsrahmen dar.

Während diese Konzepte wichtige Teilaspekte der AI-Governance adressieren, bleibt die konkrete Umsetzung und Integration in bestehende Strukturen oft unklar. Die Zusammenführung der technischen, organisatorischen, ethischen und regulatorischen Dimensionen ist daher eine zentrale Herausforderung der AI-Governance.

2.5 Normative Rahmenwerke

Neben wissenschaftlichen Konzepten und organisationalen Perspektiven spielen normative Rahmenwerke eine zentrale Rolle für die Entwicklung und Umsetzung von AI-Governance. Sie liefern konkrete Leitlinien, Standards und rechtliche Anforderungen, die Unternehmen als Orientierung dienen und gleichzeitig Mindestanforderungen festlegen. Besonders hervorzuheben sind vier zentrale Referenzen.

Der **EU AI Act** ist der erste umfassende Rechtsrahmen für Künstliche Intelligenz (KI). Er basiert auf einem risikobasierten Ansatz und unterscheidet zwischen unterschiedlichen Risikoklassen, die von minimalem bis hin zu inakzeptablem Risiko reichen. Für jede Risikoklasse werden spezifische Anforderungen an die Entwicklung, den Einsatz und die Überwachung von KI-Systemen definiert. Insbesondere Hochrisiko-Systeme – etwa im Bereich biometrischer Überwachung oder im Gesundheitswesen – unterliegen strengen Anforderungen an Transparenz, Datenqualität, Dokumentation und menschlicher Aufsicht.[12] Der EU AI Act ist deshalb wichtig, weil er einen verbindlichen rechtlichen Rahmen vorgibt, der Unternehmen dazu zwingt, Governance-Strukturen systematisch zu implementieren.

Die **Ethics Guidelines for Trustworthy AI** definieren „vertrauenswürdige KI“ entlang von sieben Schlüsselprinzipien: menschliche Aufsicht, Robustheit und Sicherheit, Datenschutz und Datenmanagement, Transparenz, Diversität, Nicht-Diskriminierung und Fairness, gesellschaftliches Wohlergehen sowie Rechenschaftspflicht.[13] Sie sind deshalb bedeutsam, weil sie einen normativen Ordnungsrahmen bieten, der über rechtliche Mindestanforderungen hinausgeht und Unternehmen ethische Leitlinien für die verantwortungsvolle Nutzung von KI-Systemen vorgibt.

[11] EC 2025, S. 14–17.
[12] Kim u. a. 2025, S. 2.
[13] EC 2025, S. 14–18.

Mit **ISO/IEC 42001:2023** wurde erstmals ein internationaler Standard für ein KI-Managementsystem veröffentlicht. Er beschreibt Anforderungen, wie Organisationen Prozesse zur Steuerung von KI systematisch etablieren, umsetzen und kontinuierlich verbessern können.[14] Dieser Standard ist wichtig, weil er es Unternehmen ermöglicht, AI-Governance in ihre bestehenden Managementsysteme – wie ISO 9001 (Qualitätsmanagement) oder ISO 27001 (Informationssicherheitsmanagement) - zu integrieren und dadurch Governance mess- und auditierbar zu machen.

Das **NIST AI Risk Management Framework (RMF)** des US-amerikanischen National Institute of Standards and Technology (NIST) stellt ein freiwilliges Rahmenwerk dar. Es beschreibt vier Kernfunktionen: *Govern, Map, Measure, Manage* und versteht „Govern“ als übergreifende Querschnittsfunktion über den gesamten Lebenszyklus eines KI-Systems.[15] Dieses Framework ist relevant, da Organisationen mit seiner Hilfe ein pragmatisches Instrument nutzen können, um Risiken im Umgang mit KI erkennen zu können und systematisch zu managen, ohne dass dies regulatorisch vorgeschrieben ist.

AI-Governance entsteht nicht im luftleeren Raum: Recht (EU AI Act), Soft-Law (Ethics Guidelines), Managementstandards (ISO/IEC 42001) und praxisnahe Rahmenwerke (NIST AI RMF) setzen Leitplanken und Anknüpfungspunkte. Vor diesem Hintergrund analysiert Kap. 3 fünf komplementäre Ansätze auf ihre Eignung für die betriebliche Steuerung. Kap. 4 bewertet diese entlang eines einheitlichen Kriterienkatalogs.

[14] ISO 2025, S. 1.

[15] National Institute of Standards and Technology 2025, S. 21–24.

3 Vorstellung & Analyse ausgewählter Modelle der AI-Governance

Zur theoretischen und praktischen Fundierung der AI-Governance wurden in den vergangenen Jahren unterschiedliche Modelle, Standards und regulatorische Ansätze entwickelt. Sie unterscheiden sich hinsichtlich Ursprung, Zielsetzung und Anwendungsbereich. Für diese Arbeit wurden fünf Modelle ausgewählt, die aufgrund ihrer Relevanz, ihrer unterschiedlichen Schwerpunkte sowie ihrer Verbreitung in Wissenschaft, Regulierung und Praxis besonders geeignet erscheinen:

- ISO/IEC 42001 (internationaler Standard für KI-Managementsysteme)[16],
- EU-AI-Act (europäischer Rechtsrahmen für KI)[17],
- NIST AI Risk Management Framework (US-amerikanisches Rahmenwerk für das Risikomanagement von KI)[18],
- Multilevel-AI-Governance-Framework (mehrstufiges Rahmenwerk für KI-Governance, wissenschaftliches Konzept)[19],
- Hourglass Model of AI Governance (organisatorischer Ansatz)[20].

Die Analyse der Modelle erfolgt nach einheitlichen Kriterien: Zunächst werden Ursprung und Aufbau des Modells vorgestellt. Anschließend werden zentrale Stärken sowie mögliche Schwächen oder Einschränkungen diskutiert.

3.1 ISO/IEC 42001

Mit der Veröffentlichung von *ISO/IEC 42001:2023* wurde erstmals ein international anerkannter Standard für KI-Managementsysteme etabliert. Der Standard wurde von der International Organization for Standardization (ISO) und der International Electrotechnical Commission (IEC) entwickelt und ist analog zu anderen Managementsystemstandards wie *ISO 9001* (Qualitätsmanagement) und *ISO 27001* (Informationssicherheitsmanagement) aufgebaut, orientiert sich demnach auch an der High-Level-Structure.[21]

[16] ISO 2025.
[17] EPRS 2024.
[18] National Institute of Standards and Technology 2025.
[19] Choung, David und Seberger 2023.
[20] Mäntymäki u. a. 2025.
[21] ISO 2025, S. 1.

3.1.1 Aufbau und zentrale Elemente

Der Standard beschreibt die Anforderungen an ein sogenanntes AI Management System (AIMS), das Organisationen dabei unterstützen soll, den Einsatz von KI-Systemen systematisch zu planen, umzusetzen, zu überwachen und kontinuierlich weiterzuentwickeln. Der Aufbau folgt dem bewährten Plan-Do-Check-Act-Zyklus (PDCA) und umfasst alle wesentlichen Aspekte einer strukturierten Steuerung.
Zu Beginn fordert ISO/IEC 42001 eine Analyse des organisatorischen Kontexts, also der internen und externen Rahmenbedingungen, die den Einsatz von KI beeinflussen. Ebenfalls sollen die Erwartungen der relevanten Interessengruppen (Stakeholder) erfasst werden. Darauf aufbauend wird die Verantwortung des obersten Managements betont, die für die Einführung und Aufrechterhaltung des AIMS verantwortlich ist. Dies umfasst insbesondere die Zuweisung von Rollen und Verantwortlichkeiten sowie die Bereitstellung notwendiger Ressourcen. Ergänzend verlangt der Standard eine systematische Planung, die Risiken und Chancen im Zusammenhang mit KI-Systemen identifiziert, messbare Ziele definiert und geeignete Maßnahmen zur Risiko- und Chancenbewältigung festlegt. Ein weiterer Schwerpunkt liegt auf Supportprozessen wie etwa der Ressourcenbereitstellung, der Kompetenzentwicklung, der internen Kommunikation sowie der Dokumentation und dem Wissensmanagement. Der operative Teil adressiert den gesamten Lebenszyklus von KI-Systemen, von der Planung über die Implementierung bis hin zur Überwachung und kontinuierlichen Verbesserung. Hierbei werden insbesondere Transparenz, Datenqualität und Nachvollziehbarkeit betont. Hinzu kommen Anforderungen an die Bewertung der Wirksamkeit des Managementsystems durch Monitoring, interne Audits und Managementbewertungen. Abschließend verlangt der Standard die kontinuierliche Verbesserung des AIMS auf Basis der gewonnenen Erkenntnisse im Laufe der Implementierung und Nutzung von KI-Systemen.[22]

3.1.2 Stärken und Schwächen

Eine besondere Stärke von ISO/IEC 42001 liegt in der strukturellen Herangehensweise und der Kompatibilität mit bestehenden ISO-Managementsystemen. Unternehmen, die bereits ISO-basierte Managementsysteme etabliert haben, können AI-Governance nahtlos integrieren. Dies erleichtert nicht nur die Implementierung, sondern schafft auch externe Nachvollziehbarkeit durch Zertifizierungen und Auditierungen. Vor allem für global agierende Organisationen bietet der Standard den Vorteil einer international anerkannten Vorgehensweise.

[22] ISO 2025, S. 5–16.

Der Standard weist jedoch auch einige Einschränkungen auf. Seine bewusst allgemeine Formulierung ermöglicht eine flexible Anpassung an unterschiedliche organisatorische Kontexte, birgt jedoch auch das Risiko von Interpretationsspielräumen und uneinheitlicher Umsetzung. Darüber hinaus liegt der Schwerpunkt stark auf organisatorischen Strukturen und Prozessen, während ethische und gesellschaftliche Fragestellungen ebenso wenig Beachtung finden wie technische Aspekte zur Risikominimierung. Für kleine und mittlere Unternehmen könnte die Umsetzung des Standards eine besondere Herausforderung darstellen, da diese möglicherweise mit erheblichem Ressourcen- und Kostenaufwand verbunden ist.

3.2 EU-AI-Act

Der **EU-AI-Act** stellt den weltweit ersten umfassenden Rechtsrahmen für den Einsatz von Künstliche Intelligenz (KI) dar. Er wurde von der Europäischen Kommission vorgeschlagen und 2024 verabschiedet. Ziel des Rechtsakts ist es, einheitliche Standards für die Entwicklung und den Einsatz von Künstliche Intelligenz (KI)-Systemen in der Europäischen Union zu schaffen. Zugleich soll Innovation gefördert und ein hohes Schutzniveau für Bürgerinnen und Bürger sichergestellt werden.[23] Grundlage bildet ein risikobasierter Ansatz, bei dem KI-Systeme nach ihrem Gefährdungspotenzial für Grundrechte und Sicherheit in verschiedene Risikoklassen eingeteilt werden.

3.2.1 Aufbau und zentrale Elemente

Der EU-AI-Act unterscheidet zwischen vier Risikoklassen:

- **Unakzeptables Risiko:** Diese Systeme sind verboten, da sie gegen grundlegende Rechte und Freiheiten verstoßen (z.B. Social Scoring durch staatliche Stellen).
- **Hochrisiko:** Hierzu zählen Systeme, die in sicherheitskritischen Bereichen wie Gesundheit, Verkehr oder Justiz eingesetzt werden. Sie unterliegen strengen Anforderungen an Transparenz, Datenqualität und menschliche Aufsicht.
- **Begrenztes Risiko:** Für diese Systeme gelten reduzierte Anforderungen, etwa im Bereich der Nutzerinformation.
- **Minimalrisiko:** Diese Kategorie umfasst Anwendungen mit geringem Risiko, für die keine speziellen Vorgaben bestehen.

[23] Kim u. a. 2025, S. 1–3.

Neben dieser Klassifikation legt der EU-AI-Act umfangreiche Pflichten für Anbieter und Betreiber von KI-Systemen fest. Dazu gehören Risikomanagementprozesse, die Sicherstellung von Datenqualität, die Dokumentation der technischen Infrastruktur, Protokollierungspflichten sowie die Gewährleistung menschlicher Aufsicht. Ergänzend wird ein Konformitätsbewertungsverfahren eingeführt, das je nach Risikoklasse unterschiedliche Anforderungen an die Nachweisführung stellt. Dieses soll sicherstellen, dass die Systeme vor ihrer Markteinführung den gesetzlichen Vorgaben entsprechen. Überwacht wird dies durch nationale Behörden und eine neu geschaffene EU-Behörde für künstliche Intelligenz (EU AI Office).

3.2.2 Stärken und Schwächen

Der EU-AI-Act überzeugt zunächst durch seinen konsequent risikobasierten Zuschnitt. Er unterscheidet klar zwischen verbotenen Praktiken, Hochrisiko-Systemen, Systemen mit begrenztem Risiko und Minimalrisiko-Anwendungen und verknüpft diese Kategorien mit abgestuften Pflichten. Für Hochrisiko-Systeme werden besonders strenge Anforderungen formuliert, die sicherstellen sollen, dass diese Systeme transparent, nachvollziehbar und unter menschlicher Aufsicht betrieben werden. Das schafft insbesondere in sensiblen Domänen wie Gesundheit und Justiz ein höheres Maß an Rechtssicherheit für Anbieter und Anwender.[24]

Zugleich stärkt der Act den Schutz der Grundrechte, indem er besonders eingriffsintensive Anwendungen ausdrücklich untersagt, darunter Social Scoring, manipulative bzw. täuschende Verfahren, eine weitreichende biometrische Fernidentifikation im öffentlichen Raum (mit Ausnahme von klar definierten Ausnahmen) und Emotionserkennung in Schulen oder der Arbeitswelt.[25] Positiv hervorzuheben ist weiterhin die institutionelle Verankerung: Nationale Marktüberwachungsbehörden, ein EU-weit koordiniertes Vollzugsnetzwerk und die neu geschaffene EU-Behörde für künstliche Intelligenz (EU AI Office) sollen die einheitliche Anwendung der Vorschriften sicherstellen und den Austausch bewährter Praktiken fördern.[26] Ergänzend adressiert der General-Purpose AI (GPAI)-Act die notwendige Dokumentation, Informationsweitergabe an Downstream-Anbieter und urheberrechtskonforme Verfahren. Für Modelle mit „high-impact capabilities“ kommen zusätzliche Pflichten zur Risikoanalyse, Vorfallsberichterstattung und Cybersicherheitsmanagement hinzu.[27]

Ebenfalls soll die Innovationsförderung nicht gehemmt werden, indem soge-

[24] EPRS 2024, S. 2–3.
[25] EPRS 2024, S. 5.
[26] EPRS 2024, S. 10–11.
[27] EPRS 2024, S. 10.

nannte Regulatory Sandboxes geschaffen werden, in denen Unternehmen neue KI-Anwendungen unter realen Bedingungen testen können, ohne sofort alle regulatorischen Anforderungen erfüllen zu müssen.[28]

Demgegenüber zeigen sich mehrere Schwächen und Umsetzungsrisiken. Erstens kritisiert die Fachliteratur eine mögliche „Cliff-Edge"-Regulierung: Während Hochrisiko-Systeme detailliert reguliert sind, verbleiben zahlreiche Anwendungen im Graubereich mit geringen oder unklaren Anforderungen. In Kombination mit dem sehr weiten Geltungsbereich („alle KI-Systeme") und der Konzentration der Pflichten auf Hochrisiko-Fälle drohen Regulierungslücken und eine faktische Präemption nationaler Schutzstandards (z.B. zu Transparenz oder Nutzungsbedingungen).[29]

Zweitens ist die starke Anlehnung an das Produktsicherheitsrecht widersprüchlich, da die Konkretisierung der Norm über Standardorganisationen erfolgen soll, die traditionell wenig Expertise in den Grundrechten haben. Z eitgleich wird die Verantwortung für die Einhaltung der Grundrechte auf die Unternehmen abgewälzt. Dies fördert die Einhaltung formaler Standards im Vergleich zu einer eingehenden Prüfung der Grundrechte.[30]

Drittens bleiben die Betroffenenrechte und „bottom-up" Durchsetzung unzureichend berücksichtigt. Trotz Transparenzinstrumenten wie dem Recht auf Zugang zu Informationen und der Möglichkeit, Beschwerde einzulegen, fehlen klar definierte Beschwerde- und Klagerechte für Betroffene.[31]

Viertens erzeugen die umfangreichen Dokumentations-, Test- und Governance-Pflichten erhebliche Compliance-Lasten, die insbesondere kleine und mittlere Unternehmen (KMU) überproportional belasten können. Gleichzeitig hängt die Wirksamkeit zentraler Schutzmechanismen von einer schnellen und inklusiven Standardisierung ab. In der Debatte wird zudem kritisiert, dass einzelne technische Schwellen zu hoch angesetzt sein könnten.[32]

Fünftens sind Anforderungen an die menschliche Aufsicht zwar vorgesehen, adressieren in der Praxis jedoch vor allem die Hersteller; Robuste, durchsetzbare organisatorische Aufsichts- und Kompetenzpflichten auf Anwenderseite bleiben teilweise nur angedeutet, was Verantwortungslosigkeit und Intransparenz begünstigen könnte.[33]

In der Summe ist der EU-AI-Act ein globaler Referenzrahmen, der risikoadäquate Pflichten, explizite Verbote, GPAI-Regeln und eine mehrstufige Governance-Architektur vereint. Das Schutzniveau wird in der Praxis jedoch wesentlich

[28] EPRS 2024, S. 4, 5.
[29] Veale und Borgesius 2021, S. 108–109.
[30] Veale und Borgesius 2021, S. 102, 106.
[31] Veale und Borgesius 2021, S. 111–112.
[32] EPRS 2024, S. 11.
[33] Veale und Borgesius 2021, S. 107–108.

von der Qualität und Inklusivität der nachgelagerten Harmonisierungs- und Standardisierungsprozesse sowie den Aufsichtsmechanismen abhängen.[34][35]

3.3 NIST AI Risk Management Framework

Das NIST AI RMF ist ein freiwilliger, sektorneutraler Rahmen zur Steuerung von KI-Risiken über den gesamten Lebenszyklus. Es adressiert alle beteiligten Akteure, liefert gemeinsame Begriffe und Aktivitäten zur Förderung vertrauenswürdiger KI und wird durch ein laufend aktualisiertes Playbook ergänzt. NIST positioniert das RMF ausdrücklich als „living document“, das kontinuierlich weiterentwickelt wird, um den dynamischen Herausforderungen der KI-Technologie gerecht zu werden.[36] Zudem macht NIST die Andersartigkeit von KI-Risiken im Vergleich zu klassischer Software deutlich und hebt die Notwendigkeit hervor, spezifische Ansätze zur Risikominderung zu entwickeln.

3.3.1 Aufbau und zentrale Elemente

Zielbild sind sieben Eigenschaften vertrauenswürdiger KI (*Sicherheit, Sicherheit und Resilienz, Erklärbarkeit und Nachvollziehbarkeit, Datenschutz, Fairness, Transparenz und Zuverlässigkeit*), die als Leitlinien für die Entwicklung und den Einsatz von KI-Systemen dienen.[37] Der sogenannte AI RMF Core umfasst vier Kernfunktionen mit Subkategorien: GOVERN, welches die Rahmenbedingungen für die Anwendungen definiert, bei denen Rollen, Richtlinien und Verantwortlichkeiten im Zusammenspiel mit der Organisationskultur berücksichtigt werden; MAP, das die Identifizierung und Bewertung von Risiken unterstützt, indem Kontext, Anwendungsfälle, Stakeholder und potenzielle Auswirkungen berücksichtigt werden; MEASURE, bei dem die Messung und Bewertung der Leistung von KI-Systemen im Vordergrund steht; und MONITOR, welches die kontinuierliche Überwachung und Verbesserung von KI-Systemen sicherstellt.[38] Weitergehend existieren AI-RM-Profile, die spezifische Anforderungen und Maßnahmen für verschiedene Anwendungsbereiche definieren, um eine zielgerichtete Umsetzung zu ermöglichen.[39]

[34] EPRS 2024, S. 11.
[35] Veale und Borgesius 2021, S. 112.
[36] National Institute of Standards and Technology 2025, S. 1–3.
[37] National Institute of Standards and Technology 2025, S. 12–18.
[38] National Institute of Standards and Technology 2025, S. 20–31.
[39] National Institute of Standards and Technology 2025, S. 33–34.

3.3.2 Risiken und Schwächen

Eine der wichtigsten Stärken des NIST AI RMF ist das soziotechnische Risikoverständnis, welches einem ganzheitlichen Ansatz zur Identifizierung und Bewertung von Risiken dient. Es werden Technik, Organisation, Prozesse und der Kontext der Anwendung berücksichtigt, um ein umfassendes Bild der Risiken zu erhalten. Mithilfe dieses Ansatzes sind nicht nur bessere Entscheidungen zu treffen, der Einsatz von KI-Technologien wird dadurch auch sicherer, fairer, erklärbarer und bezieht Grundrechte mit ein.[40]
Die Vorgehensweise des Modells mit den vier Kernfunktionen GOVERN, MAP, MEASURE und MONITOR ermöglicht eine nachvollziehbare und systematische Herangehensweise an das Management von KI-Risiken und die vorhandenen Tabellen erleichtern die operative Umsetzung.[41]
Um Vertrauen in KI-Systeme zu schaffen und eine gemeinsame Grundlage über die unterschiedlichen Disziplinen, wie etwa Recht, Ethik, Technik und Management, zu schaffen, dienen die sieben Eigenschaften vertrauenswürdiger KI als Leitlinien, die für alle Stakeholder gleich sind.[42]
Nicht nur ist das AI RMF ein freiwilliges Rahmenwerk, es kann auch entsprechend in bestehende Management- und Governance-Strukturen integriert werden und bietet mit dem MEASURE-Element eine Quantifizierung von Risiken und Maßnahmen, die eine messbare Verbesserung der KI-Governance ermöglichen.[43]
Ein weiterer Vorteil des AI RMF ist die regelmäßige Aktualisierung des Playbooks, welches die neuesten Entwicklungen und Best Practices im Bereich der KI-Governance berücksichtigt und somit eine kontinuierliche Verbesserung der Rahmenbedingungen für den Einsatz von KI-Technologien ermöglicht und die Verwendung von Best Practices fördert.[44]
Hingegen gibt es auch einige Schwächen und Herausforderungen, die bei der Implementierung und Anwendung des AI RMF berücksichtigt werden müssen. Ohne rechtliche Verbindlichkeiten bleibt die Umsetzung der Empfehlungen und Leitlinien des AI RMF oft freiwillig und kann von den Organisationen unterschiedlich interpretiert werden.[45]
NIST selbst weist darauf hin, dass Risikomessungen und Priorisierungen von Risiken eine Herausforderung darstellen, da diese oft kontextabhängig und teilweise methodisch unreif sind.[46]

[40] National Institute of Standards and Technology 2025, S. 4–5, 12–18.
[41] National Institute of Standards and Technology 2025, S. 22–31.
[42] National Institute of Standards and Technology 2025, S. 12–13.
[43] National Institute of Standards and Technology 2025, S. 33–34, 28–31.
[44] National Institute of Standards and Technology 2025, S. iii, 21.
[45] National Institute of Standards and Technology 2025, S. 1–2.
[46] National Institute of Standards and Technology 2025, S. 5–7.

Ebenfalls ist die Implementierung der Empfehlungen und Leitlinien des AI RMF oft ressourcenintensiv und erfordert eine umfassende Schulung und Sensibilisierung der Mitarbeiter.[47]
Eine weitere Schwäche ist die unterschiedliche Auslegung je nach Technologie und Anwendungsbereich, da das RMF grundsätzlich technologie- und anwendungsneutral ist. Dies führt zur Ergänzung von notwendigen Leitlinien, die je nach Organisation unterschiedlich interpretiert und umgesetzt werden können, insbesondere in Konzernen mit dezentralen Strukturen.[48]

3.4 Multilevel-AI-Governance-Framework

Das Multilevel-Framework begreift AI-Governance als Zusammenspiel aus drei Ebenen: staatlich/transnational, unternehmerisch und individuell. Es argumentiert, dass ethische Leitlinien allein ohne vermittlende Governance-Strukturen nicht in die Praxis umgesetzt werden können. Stattdessen benötigt es eine wechselseitige Verknüpfung von Top-down-Politik und Bottom-up-Erwartungen der Gesellschaft.[49] Als zentrales Bindeglied werden im Multilevel-AI-Governance-Framework drei Vertrauensdimensionen definiert: Kompetenz, Integrität und Wohlwollen.

3.4.1 Aufbau und zentrale Elemente

Das Modell verbindet die drei Ebenen – Regierung, Unternehmen und Bürger:innen – über drei Vertrauensdimensionen. Die Dimension *Kompetenz* deckt Aspekte wie Sicherheit, Robustheit, Erklärbarkeit und Rechenschaftspflichten ab. *Integrität* umfasst Fairness, Nichtdiskriminierung, Datenschutz und Transparenz. Die Dimension *Benevolence (Wohlwollen)* bezieht sich auf das Gemeinwohl und soziale Gerechtigkeit.[50]
Zusätzlich wird das Konzept mit den HLEG (High-Level Expert Group on Artificial Intelligence)-Anforderungen an vertrauenswürdige KI verknüpft.[51][52] Diese Verknüpfung zeigt auf, dass das Handeln von Unternehmen sowohl von staatlicher Regulierung als auch von der gesellschaftlichen Forderung nach vertrauenswürdiger KI beeinflusst wird. Zur Umsetzung schlägt das Konzept vor, Ethik-Audits und interne Review-Boards zu definieren, die um weitere externe Prüfmodelle analog zu der amerikanischen Behörde Food and Drug Adminis-

[47] National Institute of Standards and Technology 2025, S. 8–9.
[48] National Institute of Standards and Technology 2025, S. 1–3, 21–27.
[49] Choung, David und Seberger 2023, S. 2–5.
[50] Choung, David und Seberger 2023, S. 10.
[51] Choung, David und Seberger 2023, S. 8.
[52] EC 2025.

tration (FDA) ergänzt werden sollen.[53]

3.4.2 Stärken und Schwächen

Das Framework stellt die relevanten Akteursgruppen (Staat–Unternehmen–Bürger:innen) und ihre Interaktionen miteinander dar – dies ist hilfreich für die Implementation von Strategie- und Governance-Designs. Zudem ermöglicht die Anbindung an die HLEG-Anforderungen eine gründlichere Berücksichtigung ethischer Aspekte in der Unternehmenspraxis. Eine weitere Stärke ist die Definition der umzusetzenden Mechanismen, wie der Ethik-Audits und internen Review-Boards, zur Stärkung der Integrität, Transparenz und Rechenschaftspflicht.[54]
Auch bei diesem Modell werden Schwächen sichtbar. Das Modell bleibt abstrakt, es werden keine Metriken, Reifegrade oder Prozess-Checklisten vorgegeben.[55] Dadurch kann das Modell nicht „out of the box“ in Unternehmen implementiert werden und erschwert die Auditierbarkeit über verschiedene Branchen hinweg. Zudem ist die Dimension „Wohlwollen“ schwer operationalisierbar, da sie stark von individuellen und kulturellen Werten abhängt.[56]
Die Ethik-Audits und internen Review-Boards sind zwar ein Schritt in die richtige Richtung, jedoch können diese die Innovationskraft der Unternehmen verlangsamen, da sie zusätzliche bürokratische Hürden schaffen und Ressourcen binden. Eine Abstufung wird von den Autoren bereits angeregt, jedoch nicht genauer ausgeführt.[57]

3.5 Hourglass Model of Organizational AI Governance

Das Hourglass-Model von Mäntymäki u. a. 2025 zielt darauf, Ethikprinzipien in praktikable Governance-Mechanismen zu übersetzen und die Anforderungen aus dem Umfeld (Recht, Leitlinien, Stakeholder) über eine vermittelnde Organisationsebene bis hinunter in operative Praktiken auf Systemebene zu überführen. Die Autor:innen betonen die Übersetzungsarbeit als kontinuierlichen Prozess und berichten, dass das Modell in Kooperation mit Industriepartnern entwickelt und bei einem großen Finanzunternehmen getestet wurde.[58] Zudem wurde jedes Element des Modells am damaligen EU-AI-Act-Entwurf[59]

[53] Choung, David und Seberger 2023, S. 10.
[54] Choung, David und Seberger 2023, S. 11.
[55] Choung, David und Seberger 2023, S. 9–10.
[56] Choung, David und Seberger 2023, S. 9–10.
[57] Choung, David und Seberger 2023, S. 11.
[58] Mäntymäki u. a. 2025, S. 5.
[59] EPRS 2024.

gegengeprüft, um den Anschluss an die regulatorischen Anforderungen zu gewährleisten.[60]

3.5.1 Aufbau und zentrale Elemente

Das Modell ordnet Governance in drei Ebenen ein. Die Environmental-Ebene, die rechtliche und gesellschaftliche Inputs berücksichtigt, die Organizational-Ebene, die die Strategie- und Werteausrichtung des jeweiligen Unternehmens abbilden soll und das AI-System, welches die operative Governance umsetzt. Die Steuerung des Modells erfolgt sowohl „top-down“ mithilfe von Normen, die in Prozessen umgesetzt werden, als auch „bottom-up“ über die Rückmeldungen aus dem Systembetrieb, die in die Organisationsebene zurückfließen.[61]
Auf der Organisationsebene stehen zwei zentrale Elemente im Fokus: das „strategic alignment“ und das „value alignment“. Im „strategic alignment“ werden die strategischen Ziele des Unternehmens in Bezug auf KI um eine generelle Richtung zu identifizieren und die Erwartungen an die KI-Systeme zu definieren. Das Element des „value alignments“ hingegen fokussiert sich auf die Wertebasis und Ethik, die das Unternehmen anwenden möchte und darauf, dass die Einhaltung dieser Werte und Grundsätze in allen KI-Systemen des Unternehmens sichergestellt wird. Ein weiterer Punkt des „value alignments“ ist die Definition der Risikotoleranz, da ethische Überlegungen selten eindeutig sind und unterschiedliche Interpretationen zulassen.[62]
Die Systemebene unterteilt sich in acht operative Komponenten: das AI-System, Algorithmen, Daten, Risiken und Auswirkungen, Transparenz/Erklärbarkeit/Anfechtbarkeit, Verantwortlichkeit, Entwicklung & Betrieb und Compliance.[63] Besonders prägend ist die Verzahnung der einzelnen Komponenten mit dem KI-Lebenszyklus (OECD-Modell): Die Autor:innen verknüpfen die Governance-Prozesse mit den acht Komponenten auf Design, Entwicklung, Deployment und Monitoring.[64]

3.5.2 Stärken und Schwächen

Das Hourglass bietet eine klare Struktur, um die Übersetzung von Ethik und regulatorischen Anforderungen in konkrete Rollen und Prozesse zu ermöglichen. Weiterhin orientiert sich das Modell am kompletten Lebenszyklus der KI-Systeme statt reiner Kontrollen im Betrieb.

[60] Mäntymäki u. a. 2025, S. 3.
[61] Mäntymäki u. a. 2025, S. 5–7.
[62] Mäntymäki u. a. 2025, S. 7.
[63] Mäntymäki u. a. 2025, S. 7–12.
[64] Mäntymäki u. a. 2025, S. 9–12.

Auch die Gegenprüfung des Modells mit dem damaligen EU-AI-Act-Entwurf[65] stellt sicher, dass die regulatorischen Anforderungen angemessen berücksichtigt werden. Eine weitere Stärke des Hourglass-Modells ist die Granularität, mit der es verschiedene Aspekte der KI-Governance adressiert. Durch die detaillierte Betrachtung der einzelnen acht Komponenten in der operativen Ebene können die dafür notwendigen Rollen, Aufgaben und Artefakte klar definiert werden.

Jedoch gibt es auch Schwächen im Hourglass-Modell. Die Autor:innen weisen darauf hin, dass das Modell bisher nur einen Überblick über die Governance von KI-Systemen bietet und noch nicht alle praktischen Herausforderungen adressiert.[66] Ein weiterer Kritikpunkt ist, dass das Modell stark auf die Compliance mit regulatorischen Anforderungen fokussiert ist und weniger auf die Förderung von Innovation und Agilität in der Entwicklung von KI-Systemen eingeht. Zudem ist das Modell abhängig von der Übersetzungsleistung der Risikotoleranzen, Verantwortlichkeiten und Kapazitäten auf der Organisations- und Teamebene, da das Modell diese nur benennt, aber keine vollständige Lösung darbietet.[67]

[65] EPRS 2024.
[66] Mäntymäki u. a. 2025, S. 13.
[67] Mäntymäki u. a. 2025, S. 6–7, 12.

4 Vergleich und Bewertung (Matrix)

Ziel dieses Kapitels ist es, die fünf zuvor eingeführten Ansätze (ISOIEC 42001, EU AI Act, NIST AI RMF, Multilevel Framework, Hourglass Model) entlang eines einheitlichen Kriterienkatalogs systematisch zu vergleichen.

4.1 Bewertungslogik und Datengrundlage

Als Datengrundlage dienen die fünf zuvor beschriebenen Modelle aus Kapitel 3, deren Stärken und Schwächen, sowie die Triangulation mit drei leitfadengestützten Experteninterviews (CIO, IT-Security, Datenschutz) zur Plausibilisierung der Kriterienausprägungen (Anhang B.1). Die Bewertung erfolgt anhand des folgenden Kriterienkatalogs. Im Anschluss an die Bewertung wird ein Gesamtwert ungewichtet und gewichtet gebildet.

4.2 Kriterienkatalog

Der Kriterienkatalog umfasst drei Dimensionen mit insgesamt zwölf Kriterien (K1–K12):

4.2.1 Regulatorische/strategische Anforderungen

K1 **Verbindlichkeit & Durchsetzbarkeit:** Existenz und Wirksamkeit verbindlicher Regeln, Eskalations- und Sanktionsmechanismen (Policies, Freigaben, Stop-Kriterien). Rating 1–5.

K2 **Regulatorische Passung (EU/Branche):** Anschlussfähigkeit an EU-/sektorale Vorgaben und Zukunftsfähigkeit (Standardisierung, Codes of Practice). Rating 1–5.

K3 **Strategische Steuerbarkeit:** Klarheit von Zielbildern, Risikotoleranzen, Rollen/Ownern, Gremien und Entscheidungspunkten. Rating 1–5.

4.2.2 Operative Umsetzbarkeit

K4 **Lebenszyklus-Management:** Abdeckung von Scoping, Entwicklung/Deployment, Betrieb/Monitoring und Außerbetriebnahme. Rating 1–5.

K5 **Prüfbarkeit/Auditierbarkeit:** Nachvollziehbarkeit von Entscheidungen, Modellen, Daten und Freigaben (Logs, Doku, Artefakte, Audits). Rating 1–5.

K6 **Mess- & Metrikreife:** Verfügbarkeit/Eignung von Metriken und Tests (Robustheit, Bias/Fairness, Erklärbarkeit, Sicherheit/Privacy). Rating 1–5.

K7 **Skalierbarkeit & Integration:** Anschluss an bestehende Systeme/Prozesse (z. B. ISO/ISMS, internes Kontrollsystem, MLOps). Rating 1–5.

K8 **Ressourcen & Komplexität:** Implementierungs- und Betriebslast (Zeit, Personal, Budget), insbesondere KMU-Tauglichkeit. Rating 1–5.

4.2.3 Wert- & Stakeholderbezug

K9 **Grundrechts-/Ethiknähe & Betroffenenfokus:** Fairness, Nichtdiskriminierung, Transparenz, Contestability. Rating 1–5.

K10 **Stakeholder- & Kontextsensitivität:** Einbindung relevanter Stakeholder (z. B. DSB, CISO, Betriebsrat), Umgang mit kulturellen/organisationalen Unterschieden. Rating 1–5.

K11 **GPAI-/Ökosystem-Tauglichkeit:** Umgang mit Anbieter-/Lieferkettenanforderungen (Model Cards, Datenherkunft/IP, Kennzeichnung synthetischer Inhalte, Downstream-Hinweise). Rating 1–5.

K12 **Reifegrad & Praxisbelege:** Evidenzen aus Praxis/Piloten, Lessons Learned, Anschluss an Standardisierung. Rating 1–5.

4.3 Scoring- und Gewichtungsschema

Die Bewertung erfolgt entlang von zwölf Kriterien (K1–K12) auf einer fünfstufigen Ordinalskala: 1 = sehr schwach, 2 = schwach, 3 = angemessen, 4 = gut, 5 = sehr gut. Für die Gesamtaussage pro Modell werden alle Kriterien gleich gewichtet. Das Gesamtergebnis eines Modells ist der arithmetische Mittelwert seiner K1–K12-Scores. Zur Vermeidung von Scheingenauigkeit werden die Ergebnisse auf zwei Dezimalstellen ausgewiesen.

4.4 Einbindung der Experteninterviews in die Gesamtgewichtung

Dieses Kapitel verankert die in Kapitel 4 bewerteten Governance-Modelle in praxisnahen Prioritäten, die aus drei leitfadengestützten Experteninterviews (CIO, Head of IT-Security, Datenschutzbeauftragter) abgeleitet wurden (im Anhang B). So entsteht neben einem ungewichteten auch ein gewichteter Gesamtscore je Modell.

4.4.1 Ableitung der Gewichtung aus den Interviews

Die Interviews betonen die Notwendigkeit der Übersicht des kompletten Lebenszyklus inklusive Entscheidungsfindung- und dokumentation, sowie regelmäßige Interviews.[68] Zudem werden der Datenschutz mit Auftragsverarbeitungsverträgen und notwendiger risikobasierter Prüfung hervorgehoben.[69] Aus IT-Security Sicht ist die Berücksichtigung von Sicherheitsstandards und das Risiko des Datenabflusses von zentraler Bedeutung.[70] Zudem werden weitere Aspekte erwähnt, wie die Notwendigkeit eines pragmatischen Vorgehens in der Umsetzung, sowie strategische Steuerbarkeit, Auditierbarkeit und eine grundsätzliche Unumgänglichkeit von Schulungen.[71]
Daraus ergibt sich eine Gewichtung der Kriterien, die die in den Interviews hervorgehobenen Aspekte stärker berücksichtigt (siehe Tabelle 1).

[68] siehe Interview CIO (Anhang B.2) & Interview Datenschutzbeauftragter (Anhang B.4)
[69] siehe Interview Datenschutzbeauftragter (Anhang B.4)
[70] siehe Interview Head of IT-Security (Anhang B.3)
[71] siehe Interview CIO (Anhang B.2) & Interview Head of IT-Security (Anhang B.3) & Interview Datenschutzbeauftragter (Anhang B.4)

Tabelle 1: Gewichtung der Kriterien (K1–K12) aus den Experteninterviews

ID	Kriterium	Gewicht	Evidenz (Interview-Anker)
K1	Lebenszyklus & Entscheidungspunkte	0,12	„KI-Gremium … Entscheidungstor … fortlaufend kontrollieren …“ (CIO). „Einkauf → POC → Produktivphase → regelmäßige Kontrolle“ (DSB).
K2	Rollen & Verantwortlichkeiten	0,06	„IT, Fachbereich, Datenschutz … je nach Fall Training/Compliance/Architektur“ (CIO).
K3	Strategische Steuerbarkeit	0,10	„Erwartungsmanagement, Steuerung über Richtlinie/Prozesse/Betrieb“ (CIO).
K4	Risiko-/Klassifizierungslogik	0,09	„Risikobasierter Ansatz, jede KI individuell bewerten“ (DSB).
K5	Dokumentation & Transparenz	0,08	„Schriftliche Use-Case-Beschreibung, Stellungnahmen, Nachhaltung“ (CIO); „Transparenz als Fallstrick“ (DSB).
K6	Datenschutz	0,11	„Auftragsverarbeitung/Vertragswerk zwingend“ (DSB).
K7	IT-Sicherheit & Mindestanforderungen	0,11	„Datenabfluss als Risiko; prüfen: Speicherung, Verschlüsselung, Zugriff“ (IT-Sec).
K8	Lieferkette/GPAI/Anbieter	0,08	„Was für uns gilt, muss für Partner gelten; Dokumentation/Nachweise/Zertifizierungen“ (CIO, IT-Sec).
K9	Umsetzbarkeit & Pragmatismus	0,07	„Prozess darf nicht ausufern; Checklisten; muss funktionieren“ (IT-Sec).
K10	Change & Schulung	0,07	„Grundlagentraining + Tool-Training“ (CIO); „individuell schulen je nach Risiko“ (DSB).
K11	Auditierbarkeit	0,06	„Nachweise, Nachhaltung, Review-Prozess“ (CIO).
K12	Anpassungsfähigkeit & Skalierbarkeit	0,05	„Re-Bewertung bei Änderungen; regelmäßige Kontrollen“ (CIO, DSB).

4.4.2 Abgrenzung der gewichteten Kriterien der Interviews

Die Interviews stammen aus einem Unternehmenskontext mit einer Priorisierung von Cloud-Computing und einer heterogenen Landschaft. Zudem handelt

es sich um den Rechtsrahmen der Europäischen Union.

4.5 Darstellung der Ergebnisse

Die Resultate der Analyse werden im folgenden je Kriterium dargestellt. Am Ende des Kapitels wird die Ergebnismatrix über alle Kriterien und Modelle zusammengefasst. Dort werden die Gesamtscores, sowohl ungewichtet, als auch gewichtet, sowie die wichtigsten Erkenntnisse zu den einzelnen Modellen präsentiert.

4.5.1 K1 – Verbindlichkeit & Durchsetzbarkeit

Die Modelle unterscheiden sich stark in ihrer rechtlichen Verbindlichkeit. Der **EU AI Act** ist als Verordnung unmittelbar in allen Mitgliedsstaaten anwendbar und sieht bei Verstößen Sanktionsmechanismen und Bußgelder vor, vergleichbar zur Datenschutzgrundverordnung (DSGVO).[72][73] Damit erreicht er die höchste Durchsetzbarkeit (5/5).
Der Standard **ISO/IEC 42001** ist zwar normativ und kann über Zertifizierungen verpflichtend werden, entfaltet aber nur Wirkung, wenn Organisationen ihn aktiv anwenden; externe Sanktionen fehlen. Er wird damit im Mittelfeld bewertet (3/5).[74]
Das **NIST AI RMF** ist explizit freiwillig und sektorneutral, sodass keine rechtliche Durchsetzungskraft besteht[75]. Ähnliches gilt für das **Multilevel Framework**[76] und das **Hourglass Model**[77], die beide eher analytische bzw. konzeptionelle Orientierungen darstellen. Diese drei Modelle erreichen daher nur eine niedrige Bewertung (2/5).

4.5.2 K2 – Regulatorische Passung (EU/Branche)

Die Modelle unterscheiden sich in ihrer Anschlussfähigkeit an bestehende regulatorische Vorgaben. Der **EU AI Act** erreicht die höchste Bewertung (5/5), da er die verbindlichen EU-Vorgaben direkt definiert und durch delegierte Rechtsakte an die Mitgliedstaaten anpassungsfähig bleibt.[78][79]
Der Standard **ISO/IEC 42001** weist eine hohe Anschlussfähigkeit (4/5) auf. Als

[72] Kim u. a. 2025.
[73] EPRS 2024.
[74] ISO 2025.
[75] National Institute of Standards and Technology 2025.
[76] Choung, David und Seberger 2023.
[77] Mäntymäki u. a. 2025.
[78] Kim u. a. 2025, S. 2–3.
[79] EPRS 2024, S. 2–3.

erster internationaler Standard für KI-Managementsysteme wurde er bewusst in Einklang mit anderen ISO-Standards (z. B. ISO/IEC 27001, ISO 9001) entwickelt und fordert explizit die Berücksichtigung externer regulatorischer Anforderungen im AI Management System.[80] Da er freiwillig bleibt, fehlt jedoch die unmittelbare Rechtsbindung.
Das **NIST AI RMF** liegt im Mittelfeld (3/5). Es ist in den USA weit verbreitet und aufgrund seiner Modellagnostik und Offenheit teilweise anschlussfähig, jedoch primär für den US-Kontext entwickelt.[81] Ähnlich wird das **Multilevel Framework** bewertet (3/5), das durch die Integration verschiedener Governance-Ebenen theoretisch gut passt, aber noch ohne praktische Regelungsanbindung bleibt.[82]
Das **Hourglass Model** zeigt die geringste regulatorische Passung (2/5), da es stärker auf interne Governance-Praktiken fokussiert ist und nur begrenzte Anknüpfungspunkte an EU- oder branchenspezifische Vorgaben bietet obwohl ein Abgleich mit der damaligen Vorlage zum EU AI Act stattfand.[83].

4.5.3 K3 – Strategische Steuerbarkeit

Der Standard **ISO/IEC 42001** unterstützt Organisationen bei der Definition einer klaren KI-Politik, Rollen und Verantwortlichkeiten sowie bei der Festlegung von Risikobereitschaft und Entscheidungsprozessen Damit bietet er eine solide Grundlage für strategische Steuerung (4/5).[84]
Der **EU AI Act** zwingt Unternehmen zwar zu Risikomanagement, Konformitätsbewertung und Dokumentation (Art. 9, Art. 17), schreibt jedoch keine strategischen Steuerungsprozesse wie Zielbilder oder Gremien explizit vor. Die Steuerbarkeit ergibt sich daher eher indirekt (3/5).[85]
Das **NIST AI RMF** betont Governance-Funktionen und verlangt die Festlegung von Rollen, Risikoprofilen und Entscheidungsprozessen. Es unterstützt Unternehmen bei der strategischen Steuerbarkeit (4/5), bleibt aber freiwillig.[86]
Das **Multilevel Framework** weist auf die Verteilung von Governance-Verantwortlichkeiten über verschiedene Ebenen hin und stärkt damit die strategische Perspektive. Konkrete interne Steuerungsmechanismen fehlen jedoch (3/5).[87]
Das **Hourglass Model** fokussiert auf die Übersetzung ethischer Prinzipien in praktische Anwendungen und betont die Rolle von Governance-Instanzen im mittleren Teil der „Sanduhr“. Dies fördert strategische Reflexion, liefert aber nur

[80] ISO 2025, S. vi–vii, S. 5.
[81] National Institute of Standards and Technology 2025.
[82] Choung, David und Seberger 2023.
[83] Mäntymäki u. a. 2025.
[84] ISO 2025, Kap. 4.1, 5.1–5.3.
[85] EPRS 2024, S. 3–4.
[86] National Institute of Standards and Technology 2025, S. 6–8.
[87] Choung, David und Seberger 2023, S. 7–9.

bedingt operative Steuerungsinstrumente (3/5).[88]

4.5.4 K4 – Lebenszyklus-Management

Der Standard **ISO/IEC 42001** deckt mit seinem Managementsystem-Ansatz die Phasen von Planung, Entwicklung, Betrieb und Außerbetriebnahme ab (4/5).[89]
Der **EU AI Act** regelt den gesamten Lebenszyklus von Hochrisiko-Systemen durch Anforderungen an Risikomanagement, Datenqualität, Human Oversight, Konformität und Rückrufmechanismen, jedoch werden die weniger risikoreichen Systeme unbeachtet gelassen (3/5).[90]
Das **NIST AI RMF** ist explizit auf den gesamten AI-Lifecycle ausgelegt und baut seine Kernfunktionen (Map, Measure, Manage, Govern) entlang aller Phasen auf. Dies rechtfertigt die höchste Bewertung (5/5).[91]
Das **Multilevel Framework** adressiert eher politische Ebenen der Governance und deckt Unternehmens-Lifecycle-Aspekte nur indirekt ab (3/5).[92]
Auch das **Hourglass Model** beinhaltet den kompletten Lifecycle, fokussiert primär zwar auf die Übersetzung von Prinzipien in Praktiken und bietet keine durchgehende Lifecycle-Orientierung, jedoch werden alle notwendigen Prozesse auf Basis des vom OECD entworfenen AI system lifecycle abgebildet (4/5).[93]

4.5.5 K5 – Prüfbarkeit & Auditierbarkeit

Der Standard **ISO/IEC 42001** sieht umfassende Dokumentation, interne Audits und Management-Reviews vor, die eine gute Prüfbarkeit ermöglichen (4/5).[94]
Der **EU AI Act** fordert umfangreiche Dokumentationspflichten, Protokollierung und externe Konformitätsbewertungen. Dies gewährleistet höchste Auditierbarkeit (5/5).[95]
Das **NIST AI RMF** betont Transparenz und Nachvollziehbarkeit, bietet Organisationen Playbooks für Assessments, bleibt aber freiwillig und ohne externe Prüfpflicht (4/5).[96]
Das **Multilevel Framework** adressiert Governance eher abstrakt und beschreibt Auditmechanismen im Bereich der Ethik, die weniger relevant für die technische und organisatorische Umsetzung sind (2/5).[97]

[88] Mäntymäki u. a. 2025, S. 4–5.
[89] ISO 2025, Kap. 6–10.
[90] EPRS 2024, S. 3–5.
[91] National Institute of Standards and Technology 2025, S. 6–8.
[92] Choung, David und Seberger 2023, S. 7–9.
[93] Mäntymäki u. a. 2025, S. 8–10.
[94] ISO 2025, Kap. 9.
[95] EPRS 2024, S. 4–6.
[96] National Institute of Standards and Technology 2025, S. 8–10.
[97] Choung, David und Seberger 2023, S. 7–9.

Das **Hourglass Model** stärkt interne Verantwortlichkeiten und Prozesse, bietet aber keine systematische Auditstruktur (3/5).[98]

4.5.6 K6 – Mess- & Metrikreife

Der Standard **ISO/IEC 42001** fordert die Definition von Messmethoden und Performance-Indikatoren, stellt jedoch keine spezifischen KI-Metriken bereit (3/5).[99]
Der **EU AI Act** schreibt umfangreiche Tests und Prüfungen für Datenqualität, Robustheit, Bias und Transparenz vor, überlässt die konkrete Ausgestaltung jedoch der Standardisierung (4/5).[100].
Das **NIST AI RMF** geht am weitesten, da es explizite Metriken und Messansätze für Trustworthiness Characteristics wie Fairness, Robustness und Erklärbarkeit vorgibt (5/5).[101]
Das **Multilevel Framework** bleibt theoretisch und enthält keine Vorgaben für Metriken (2/5).[102]
Das **Hourglass Model** betont Evaluation im Rahmen der Übersetzung ethischer Prinzipien, liefert aber keine standardisierten Metriken (3/5).[103]

4.5.7 K7 – Skalierbarkeit & Integration

Der Standard **ISO/IEC 42001** wurde auf Basis der High-Level Structure (HLS) entwickelt und ist dadurch besonders gut mit anderen ISO-Standards kombinierbar. Dies macht ihn hoch skalierbar und integrationsfähig (5/5).[104]
Der **EU AI Act** ist verbindlich, aber regulatorisch relativ starr. Integration ist möglich, erfordert jedoch erheblichen Aufwand und ist für KMU teils problematisch (3/5)[105].
Das **NIST AI RMF** ist flexibel, modellagnostisch und kann in bestehende Risk- und Compliance-Systeme integriert werden, ohne explizite Standardkompatibilität wie bei ISO (4/5).[106].
Das **Multilevel Framework** ist für betriebliche Integration wenig geeignet, da es primär politische Ebenen adressiert (2/5).[107]

[98] Mäntymäki u. a. 2025, S. 4–6.
[99] ISO 2025, Kap. 9.1.
[100] EPRS 2024, S. 4–6.
[101] National Institute of Standards and Technology 2025, S. 9–12.
[102] Choung, David und Seberger 2023, S. 7–10.
[103] Mäntymäki u. a. 2025, S. 4–6.
[104] ISO 2025, Kap. 4–8.
[105] EPRS 2024, S. 6–7.
[106] National Institute of Standards and Technology 2025, S. 6–8.
[107] Choung, David und Seberger 2023, S. 7–10.

Das **Hourglass Model** bietet theoretische Anschlussfähigkeit, liefert aber keine strukturierten Integrationsmechanismen (3/5).[108]

4.5.8 K8 – Ressourcen & Komplexität

Der Standard **ISO/IEC 42001** verlangt den Aufbau eines vollständigen Managementsystems. Dies ist für große Organisationen durchführbar, für KMU jedoch ressourcenintensiv (3/5).[109]
Der **EU AI Act** verursacht hohen Umsetzungsaufwand, da umfangreiche Pflichten erfüllt werden müssen. Trotz vorgesehener Unterstützungsmaßnahmen für KMU bleibt die Komplexität hoch (2/5).[110]
Das **NIST AI RMF** ist flexibel und modulartig, sodass auch kleinere Organisationen es ressourcenschonend anwenden können (4/5).[111]
Das **Multilevel Framework** ist theoretisch ressourcenarm, in der praktischen Umsetzung aber schwer nutzbar (3/5).[112]
Das **Hourglass Model** liefert konzeptionelle Orientierung, erfordert aber eigene Konkretisierung in Unternehmen (3/5).[113]

4.5.9 K9 – Grundrechts-/Ethiknähe & Betroffenenfokus

ISO/IEC 42001 fordert die Berücksichtigung externer regulatorischer und ethischer Anforderungen, bleibt dabei jedoch auf Managementsystem-Ebene und ohne konkrete Ethik-Tools (3/5).[114]
Der **EU AI Act** enthält explizite Anforderungen an Grundrechte, Datenqualität, Bias-Vermeidung und Transparenz, stellt jedoch die Anfechtbarkeit der Verwendung weniger stark heraus (4/5)[115].
Das **NIST AI RMF** betont „Trustworthiness Characteristics“ wie Fairness, Transparenz und Datenschutz und bietet methodische Hilfen zur Operationalisierung, ohne direkten Grundrechtsbezug (4/5).[116]
Das **Multilevel Framework** verweist auf öffentliche Werte und Accountability im Zusammenspiel von Governance-Ebenen, bleibt aber abstrakt (3/5).[117]
Das **Hourglass Model** setzt die Übersetzung ethischer Prinzipien in Unternehmenspraktiken in den Fokus und adressiert explizit Fairness, Transparenz und

[108] Mäntymäki u. a. 2025, S. 4–6.
[109] ISO 2025, Kap. 4–10.
[110] EPRS 2024, S. 6–7.
[111] National Institute of Standards and Technology 2025, S. 6–9.
[112] Choung, David und Seberger 2023, S. 7–10.
[113] Mäntymäki u. a. 2025, S. 4–6.
[114] ISO 2025, Kap. 4.1.
[115] EPRS 2024, S. 2–5.
[116] National Institute of Standards and Technology 2025, S. 9–12.
[117] Choung, David und Seberger 2023, S. 8–11.

Anfechtbarkeit aus der Perspektive der Betroffenen (5/5).[118].

4.5.10 K10 – Stakeholder- & Kontextsensitivität

Der Standard **ISO/IEC 42001** verlangt die systematische Berücksichtigung relevanter Stakeholder und deren Anforderungen im Managementsystem (4/5).[119]
Der **EU AI Act** berücksichtigt Stakeholder primär über Transparenzpflichten und Betroffenenrechte, nicht jedoch umfassend im internen Governance-Kontext (3/5).[120]
Das **NIST AI RMF** fordert explizit die Einbindung von Stakeholdern und den Kontextbezug als Kernprinzip (4/5).[121]
Das **Multilevel Framework** hebt die Rolle verschiedener Akteursebenen und deren Wechselwirkungen hervor und adressiert dadurch Stakeholder- und Kontextsensitivität besonders stark (4/5).[122]
Auch das **Hourglass Model** betont die Einbindung verschiedener Stakeholder im Governance-Layer und bietet eine klare Übersetzungsfunktion zwischen Prinzipien und Praktiken (4/5).[123]

4.5.11 K11 – GPAI-/Ökosystem-Tauglichkeit

ISO/IEC 42001 fordert die Berücksichtigung externer Anforderungen und adressiert auch Zulieferketten, bleibt jedoch unspezifisch hinsichtlich Model Cards oder Datenherkunft (3/5).[124]
Der **EU AI Act** enthält umfassende Anforderungen an Datenherkunft, Dokumentation und Kennzeichnung synthetischer Inhalte sowie klare Pflichten entlang der Lieferkette (5/5).[125].
Das **NIST AI RMF** betont Supply-Chain-Risiken und empfiehlt Transparenzinstrumente wie Model Cards, bleibt jedoch freiwillig (4/5).[126]
Das **Multilevel Framework** adressiert Ökosystem-Governance theoretisch, ohne konkrete Tools (3/5).[127]
Das **Hourglass Model** fokussiert auf interne Prozesse und behandelt Ökosystem-Fragen nur am Rande (2/5).[128]

[118] Mäntymäki u. a. 2025, S. 3–6.
[119] ISO 2025, Kap. 4.2.
[120] EPRS 2024, S. 2–5.
[121] National Institute of Standards and Technology 2025, S. 7–9.
[122] Choung, David und Seberger 2023, S. 8–11.
[123] Mäntymäki u. a. 2025, S. 4–6.
[124] ISO 2025, Kap. 4.1, 8.1.
[125] EPRS 2024, S. 4–7.
[126] National Institute of Standards and Technology 2025, S. 11–13.
[127] Choung, David und Seberger 2023, S. 9–12.
[128] Mäntymäki u. a. 2025, S. 5–6.

4.5.12 K12 – Reifegrad & Praxisbelege

Der Standard **ISO/IEC 42001** ist bereits in Verwendung vieler Unternehmen und profitiert von der etablierten ISO-Struktur (5/5).[129]
Der **EU AI Act** ist bereits in Kraft (5/5).[130]
Das **NIST AI RMF** ist bereits breit angewandt und durch viele Praxisprojekte erprobt, weshalb hier die höchste Bewertung vergeben wird (5/5).[131]
Das **Multilevel Framework** ist ein theoretisches Konzept ohne breite Praxiserprobung (2/5).[132]
Das **Hourglass Model** wurde in ersten Fallstudien getestet, ist aber noch nicht im Unternehmensalltag etabliert (3/5).[133]

4.6 Gesamtbewertung der Modelle (K1–K12)

Die konsolidierte Betrachtung der Kriterien K1–K12 (Tabelle 2) zeigt, dass kein Einzelrahmen den gesamten Anforderungskatalog vollständig abdeckt. Das *NIST AI RMF* erzielt die höchste Passung in Bezug auf operative Steuerbarkeit, Risikoorientierung und lebenszyklusbezogene Prozessreife (insb. K2–K6). Der *EU AI Act* adressiert Rechtssicherheit, Nachweis- und Durchsetzbarkeit (K7–K9) besonders stark, bietet jedoch weniger operative Implementierungsleitfäden. *ISO/IEC 42001* stärkt Managementsystematik und Auditierbarkeit, geht aber mit höherem Einführungsaufwand einher. Das *Multilevel Framework* und das *Hourglass Model* überzeugen vor allem in der Governance-Architektur (Rollen, Schnittstellen, Kopplung von Top-down und Bottom-up), bleiben jedoch weniger granular hinsichtlich konkreter Kontrollmechanismen.
Die Experteninterviews führen zu einer moderaten Umgewichtung zugunsten von Prüfbarkeit, klaren Verantwortlichkeiten und Veränderungsfähigkeit. Daraus ergibt sich eine belastbare Präferenz für einen hybriden Ansatz: *NIST AI RMF* dient als prozessualer Kern (Risikomanagement und Lebenszyklussteuerung), das *Hourglass Model* liefert die Struktur- und Rollenlogik, der *EU AI Act* setzt die verbindliche Compliance-Leitplanke. *ISO/IEC 42001* wird kontextabhängig zur Reifegrad- und Audit-Readiness ergänzt, das *Multilevel Framework* stützt die organisations- und ökosphärenweite Einbettung.

[129] ISO 2025, S. vi–vii.
[130] EPRS 2024, S. 2–3.
[131] National Institute of Standards and Technology 2025, S. 3–6.
[132] Choung, David und Seberger 2023, S. 7–12.
[133] Mäntymäki u. a. 2025, S. 6–7.

Tabelle 2: Gesamtbewertung der Modelle (K1–K12) inkl. Gesamt-Scores

Kriterium	ISO/IEC 42001	EU AI Act	NIST AI RMF	Multi-level Frame-work	Hour-glass Model
K1: Verbindlichkeit	3	5	2	2	2
K2: Regulatorik	4	5	3	3	2
K3: Steuerbarkeit	4	3	4	3	3
K4: Lebenszyklus	4	3	5	3	4
K5: Prüfbarkeit	4	5	4	2	3
K6: Messreife	3	4	5	2	3
K7: Skalierbarkeit	5	3	4	2	3
K8: Ressourcen	3	2	4	3	3
K9: Ethiknähe	3	4	4	3	5
K10: Stakeholdersensitivität	4	3	4	4	4
K11: Ökosystem-Tauglichkeit	3	5	4	3	2
K12: Reifegrad	5	5	5	2	3
Ungewichteter Gesamtscore	**3,75**	**3,92**	**4,00**	**2,67**	**3,08**
Gewichteter Gesamtscore	**3,72**	**3,84**	**3,95**	**2,6**	**3,06**

Skala: 1 = sehr gering, 5 = sehr hoch.

5 Reflexion

Ziel dieses Kapitels ist es, die in der vergleichenden Bewertung (K1–K12) gewonnenen Befunde kritisch einzuordnen, ihre Aussagekraft und Grenzen offenzulegen und die Implikationen für eine belastbare AI-Governance abzuleiten. Die Reflexion stützt sich auf drei Bausteine: (1) die resultierende Matrix aus der Analyse, (2) die Intervieweinschätzungen unterschiedlicher Rollen und (3) die in der Literatur diskutierten Profilstärken der betrachteten Modelle.

5.1 Auswertung der Matrix

Die Matrix der Modelle verdeutlicht klare Stärkenprofile: Der EU AI Act erreicht hohe Werte bei Verbindlichkeit, regulatorischer Passung, Auditierbarkeit, GPAI-/Ökosystemtauglichkeit und der Reifegrad- und Praxisbelege (K1, K2, K5, K11, K12). Das NIST AI RMF überzeugt insbesondere bei Lebenszyklusabdeckung, Mess- und Metrikreife sowie Praxisbelegen (K4, K6, K12). ISO/IEC 42001 sticht durch Skalierbarkeit und Integration in bestehende Managementsystemland-

schaften hervor (K7) und stärkt damit strategische Steuerbarkeit und Auditfähigkeit. Das Hourglass Model betont den Grundrechts-, Ethik- und Betroffenenfokus (K9), während das Multilevel Framework Stakeholder- und Kontextsensitivität systematisch in den Blick nimmt (K10). Insgesamt zeigt sich: Es handelt sich weniger um substitutive, sondern vor allem um komplementäre Stärken.

5.2 Einordnung anhand der Interviewperspektiven

Die Rollenperspektiven verstärken die beobachteten Stärken der jeweiligen Modelle.
Aus der Sicht des CIO sind klare Entscheidungspunkte und eine fortlaufende Kontrolle über den Lebenszyklus zentral. Dies korrespondiert mit den hohen Werten des Lebenszyklus-Managements und der Auditierbarkeit (K4, K5).
Die Perspektive des Datenschutzes sieht rechtliche Mindestanforderungen, wie Auftragsverarbeitung und Transparenz der Datenflüsse im Vordergrund. Da diese Perspektive durch den EU AI Act geprägt ist, spiegeln die hohen Werte in K1, K2 und K5 des EU AI Acts ebendiese wieder.
Aus IT-Security-Sicht rücken Speicherung, Verschlüsselung und Zugriffsmodelle in den Fokus. Die Kriterien K7 und K11 prüfen ebendiese Aspekte von technischen Mindeststandards und der Ökosystemtauglichkeit.
Zugleich verweisen die Interviews auf Erwartungsmanagement, praktikable Prozesse und Schulungsbedarfe. Diese spiegeln sich in den Kriterien der Skalierbarkeit/Integration (K7) und der Stakeholder- und Kontextsensitivität (K10).

5.3 Aussagekraft und Grenzen der Bewertung

Die Bewertungsmatrix bietet eine transparente, nachvollziehbare Verdichtung der Anfoderungen, bleibt jedoch heuristisch. Zum einen ist das Bewertungsschema vereinfacht und kann Grenzfälle nicht adäquat abbilden. Zum anderen stellen die Kriterien nur eine Auswahl an möglichen Aspekten dar und können nicht alle relevanten Dimensionen abdecken. Weiterhin ist die Gewichtung der Kriterien, basierend auf den Interviews, subjektiv und spiegelt Rollenpräferenzen wider. Auch Wechselwirkungen zwischen den Kriterien werden nur indirekt berücksichtigt.
Die Ergebnisse sind daher als begründete, aber kontextabhängige Einschätzungen zu verstehen. Sie sind kein endgültiges Urteil, sondern bieten Anhaltspunkte für weitere Diskussionen und Entwicklungen.

5.4 Übertragbarkeit und Kontextabhängigkeit

Die Anwendbarkeit variiert mit Organisationsgröße, Notwendigkeit von Regulierungen und der IT-Reife. In stark regulierten Umfeldern und Konzernen sind die Anforderungen an Verbindlichkeit, Auditierbarkeit und Nachvollziehbarkeit deutlich höher. Während in KMU die Umsetzbarkeit, Ressourcenschonung und Integration in bestehende Praktiken im Vordergrund stehen. Dabei ist eher eine schlanke Governance gefragt, die einen einfachen und pragmatischen Einstieg ermöglicht, bevor formale Strukturen etabliert werden. In innovationsgetriebenen Unternehmen ist die Balance zwischen Flexibilität und verbindlichen Anforderungen an Governance und Compliance entscheidend.

6 Empfehlungen für die Gestaltung von AI-Governance

Dieses Kapitel formuliert kompakte Empfehlungen für den Aufbau einer praxistauglichen AI-Governance auf Basis dreier komplementärer Modelle: Hourglass als werteorientierter Orientierungsrahmen, EU AI Act als verbindlicher Rechtsrahmen und NIST AI RMF als operatives Lebenszyklusmodell. Es wird kein neues Modell daraus entwickelt. Die Kombination wird gezielt genutzt, um technische und organisatorische Anforderungen in den Vordergrund zu stellen und rechtliche sowie ethische Aspekte mitzuführen, ohne sie zum dominanten Gestaltungsprinzip zu machen.

6.1 Begründung der Kombination

Die drei Modelle schließen unterschiedliche Lücken. Das Hourglass-Modell ermöglicht es, Grundrechte, Fairness, Zweckbindung, Transparenz und Verantwortlichkeit in verschiedenen Anwendungsfällen zu berücksichtigen und verhindert rein technologiegetriebene Entscheidungen. Der EU AI Act legt klare Mindeststandards fest bezüglich der Risikobewertung, Dokumentation, Transparenz, Lieferkettenanforderungen und Nutzerinformationen, um Rechtssicherheit zu gewährleisten. Das NIST AI RMF wandelt Werte und Verpflichtungen in wiederholbare Praktiken um, die den gesamten Lebenszyklus abdecken und es ermöglichen Qualität, Risiko und Betrieb zu überwachen und zu kontrollieren. Durch die Verbindung entsteht ein robustes Rahmenwerk, das auf Werten basiert, rechtlich abgesichert ist und operativ durchführbar ist. Dieses Rahmenwerk kann einfach implementiert werden und später erweitert werden, ohne dass hohe Anfangshürden bestehen.

6.2 Stärken, Schwächen und Abdeckung

Jedes Modell hat deutliche Vorzüge und natürliche Einschränkungen. Hourglass ist überzeugend in Bezug auf normative Ausrichtung, aber nicht verbindlich und enthält keine betrieblichen Richtlinien. Der EU AI Act stellt verbindliche Regeln auf, behandelt jedoch Prozesse, Metriken und Betriebsfragen nur indirekt. NIST AI RMF ist zwar im Bereich Lebenszyklus, Risiko und Messlogik sehr kompetent, berücksichtigt jedoch keine gesetzlichen Mindestanforderungen
. Durch die Kombination werden Doppelaufwände minimiert: Werte und Grenzen werden frühzeitig definiert (Hourglass), die Pflichten werden klar und überprüfbar festgelegt (EU AI Act) und die Umsetzung erfolgt gemäß einer etablierten Betriebslogik mit klaren Messpunkten und Verantwortlichkeiten (NIST).

6.3 Praktische Grundstruktur mit technischem und organisatorischem Fokus

Für die Praxis genügt eine schlanke Grundstruktur, die interne Zusammenarbeit erleichtert. Zuerst sollten die Anwendungsfälle von KI anhand von Wert und Zweck beschrieben, dann rechtlich eingeordnet und mit den erforderlichen Nachweisen versehen werden. Die Umsetzung erfolgt gemäß einem definierten Prozess mit klaren Verantwortlichkeiten, wenigen aussagekräftigen Messpunkten und festgelegten Eskalationswegen.
Im Fokus sollten technische Kontrollen, wie transparente Datenquellen und Systemdokumentation, Zugriffsberechtigungen basierend auf Rollen und das Protokollieren wichtiger Aktionen stehen. Um die Entscheidungen nachvollziehbar zu machen, sollte ein Gremium errichtet werden, welches unterschiedliche Funktionen (z.B. Datenschutz, Fachabteilung, IT) umfasst, während die fachliche Kompetenz und Verantwortung je Anwendungsfall klar zugeordnet bleibt.
Dabei ist es wichtig bereits zu Beginn die rechtlichen und ethischen Aspekte zu berücksichtigen, ohne die technische und praktische Umsetzbarkeit zu vernachlässigen.

6.4 Erweiterbarkeit um ISO/IEC 42001 und Multilevel Framework

Auch eine Erweiterung mit den Normen ISO/IEC 42001 und dem Multilevel Framework ist denkbar.
Das ISO/IEC 42001 kann genutzt werden, um die AI-Governance in bestehende Managementsysteme zu integrieren und ggf. notwendige Audits und Zertifizierungen für Unternehmen ermöglichen.
Das Multilevel Framework kann ergänzend eingesetzt werden, um die Governance-Strukturen um unterschiedliche Interessensgruppen, unterschiedliche Organisationen oder länderübergreifende Aspekte zu erweitern, zum Beispiel bei der Einführung konzernweiter Richtlinien.
Beide Erweiterungen dienen gezielt der Verbesserung der Auditfähigkeit, der Skalierung über Organisationseinheiten oder Stakeholder-Komplexität. Sie sind jedoch nicht zwingend erforderlich, um ein nachhaltiges AI-Governance-Modell zu etablieren.

6.5 Hinweise zur Umsetzungstiefe

Die Möglichkeiten der Umsetzungstiefe sind je nach Reifegrad und Regulierungskontext unterschiedlich. In kleineren Organisationen ist es sinnvoll, eine

pragmatische Herangehensweise zu wählen, bei denen zentrale Tools und kurze Freigabewege genutzt werden, um die Hürde für die Implementierung zu senken. In Konzernen und stark regulierten Sektoren nimmt die Tiefe der Dokumentation und die Komplexität der Prüfung zu, wobei die Kombination aus EU AI Act und NIST AI RMF die Nachweisführung erleichtert.
Unabhängig von der Situation bleibt der Kern gleich: Die Unternehmenswerte geben die Richtung vor, der EU AI Act sichert die Einhaltung der rechtlichen Mindestanforderungen ab und das NIST-Vorgehen macht die Steuerung im technischen und organisatorischen Alltag möglich.

7 Fazit und Ausblick

7.1 Fazit

Die Untersuchung zeigt, dass kein einzelner Referenzrahmen die Anforderungen einer belastbaren AI-Governance vollumfänglich abdeckt. Die vergleichende Bewertung (K1–K12) und die Interviewperspektiven weisen konsistent auf komplementäre Stärken hin: Der EU AI Act bietet Verbindlichkeit, klare Pflichten und Prüfbarkeit; das NIST AI RMF liefert die operative Lebenszyklus- und Messlogik; das Hourglass-Modell verankert Entscheidungen in Grundrechten, Zweckbindung, Transparenz und Verantwortlichkeit. ISO/IEC 42001 stärkt bei Bedarf die Managementsystem- und Auditfähigkeit, das Multilevel Framework erhöht Kontext- und Stakeholdersensitivität. Als praxisnahe Konsequenz empfiehlt sich eine Kombination, die technische und organisatorische Umsetzung in den Vordergrund stellt, rechtliche Mindestanforderungen zuverlässig erfüllt und ethische Leitplanken früh adressierbar macht. Damit entsteht ein schlankes, skalierbares Gerüst, das Anwendungsfälle vom Scoping bis zum Betrieb steuert und zugleich anschlussfähig an bestehende Strukturen (z. B. ISMS/QMS) bleibt.

7.2 Beitrag der Arbeit

Die Arbeit bündelt drei Elemente: Erstens eine transparente, kriterienbasierte Gegenüberstellung relevanter Governance-Modelle. Zweitens die Einbindung rollenbezogener Praxisanforderungen aus Experteninterviews in die Gewichtung. Drittens handlungsorientierte Empfehlungen für ein kombiniertes Governance-Design, das ohne neue Theorieebenen auskommt und direkt in operative Prozesse, Rollen und Nachweise übersetzt werden kann. Der Schwerpunkt liegt auf technischer und organisatorischer Implementierbarkeit mit Touchpoints zu Recht und Ethik.

7.3 Grenzen

Die Bewertungsmatrix ist heuristisch und verdichtet komplexe Eigenschaften auf Skalenwerte; Wechselwirkungen zwischen Kriterien werden nur indirekt erfasst. Die Gewichtung spiegelt präferierte Rollenperspektiven wider und beruht auf einer begrenzten Zahl von Interviews. Kontextspezifische Faktoren (Branche, Reifegrad, Regulierungsdruck) lassen sich nicht vollständig generalisieren. Regulatorische und technische Entwicklungen sind dynamisch; Aussagen zur Passung können sich mit neuen Auslegungen, Standards oder Produktgenera-

tionen verschieben.

7.4 Ausblick

Für die Praxis bietet sich eine gestufte Umsetzung an, die mit einer verbindlichen Policy, einem Register und wenigen Anwendungsfällen beginnt und über iterative Reviews schrittweise vertieft wird. Es wird empfohlen, die Abläufe mit einigen konstanten Kennzahlen zu überwachen, wie beispielsweise den Durchlaufzeiten der Entscheidungspunkte und der Dokumentationsvollständigkeit. Mit zunehmender Reife besteht die Möglichkeit, die Kombination um ISO/IEC 42001 zu erweitern, um sie formell in Managementsysteme zu integrieren. Das Multilevel Framework unterstützt die passende Gestaltung in komplexen Stakeholder- und Länderverbünden. Es würde im Bereich der Forschung Sinn machen, eine Studie über einen längeren Zeitraum durchzuführen, um den Aufwand für die Governance, den Nutzen und die Risikoentwicklung in verschiedenen Kontexten zu untersuchen (KMU gegenüber Konzernen; Innovation gegenüber Regulierung). Außerdem ist es sinnvoll, die Steuerung der Lieferketten für GPAI-Komponenten zu analysieren und die Effektivität von Schulungen und Kommunikation im Kampf gegen Schattenlösungen zu überprüfen.
Insgesamt unterstreichen die Resultate: Die Stärke liegt nicht in einem einzelnen Modell, sondern in einer gezielten Kombination – basierend auf Werten, Rechtskonformität und operativer Steuerbarkeit.

Appendix

A Appendix

B Interviews

Dieser Anhang dokumentiert drei leitfadengestützte, halbstrukturierte Expertengespräche zur unternehmensinternen KI-Governance. Ziel ist es, rollenbasierte Anforderungen, Chancen und Risiken zu erfassen und die im Hauptteil bewerteten Governance-Ansätze zu fundieren. Der finale Leitfaden (B.1) ging allen Gesprächen voraus; die nachfolgenden Transkripte (A.2–A.4) sind anonymisiert und zum Lesefluss minimal redaktionell geglättet. Das CIO-Interview wurde per Microsoft Teams geführt, die Gespräche mit IT-Security und Datenschutz fanden vor Ort statt. Alle Teilnehmenden gaben eine Einwilligung zur Aufzeichnung und Transkription; die Aussagen spiegeln persönliche, rollenbezogene Einschätzungen wider.

B.1 Interviewleitfaden

Der folgende Leitfaden bildet die methodische Grundlage der drei Expertengespräche zur unternehmensinternen KI-Governance. Er strukturiert die Interviews in thematische Blöcke (u. a. Rolle/Kontext, Ist-Stand und Ziele, Prozesse/Kontrollen entlang des KI-Lebenszyklus, Risiken/Security/Compliance, Referenzrahmen, Enablement) und stellt offene Beispielfragen bereit. Die Gestaltung ist bewusst halbstrukturiert: Reihenfolge und Vertiefung wurden situativ angepasst; gezielte Nachfragen (Probing) waren vorgesehen, ohne die Antworten inhaltlich zu lenken. Der Leitfaden wurde in allen drei Gesprächen angewendet. Vor Beginn lag jeweils eine Einwilligung zur Aufzeichnung und Transkription vor.
„Vielen Dank, dass Sie sich Zeit für dieses Interview genommen haben. Ziel ist es, Ihre Perspektive auf die Governance von Künstlicher Intelligenz im Unternehmen zu verstehen. Die Ergebnisse werden anonymisiert und ausschließlich im Rahmen meiner wissenschaftlichen Seminararbeit verwendet. Das Interview dauert ca. 30–45 Minuten. Ich würde gerne das Gespräch mitschneiden bzw. das Teams-Transkript verwenden – ist das für Sie in Ordnung?“

- Block A - Einstieg & Rollenbezug
    1. Wie sieht ihre aktuelle Rolle und Verantwortung im Unternehmen aus?
    2. Inwiefern haben Sie derzeit Berührungspunkte mit dem Thema Künstliche Intelligenz?

3. Welche Entwicklungen oder Herausforderungen beobachten Sie im Unternehmen oder Ihrer Funktion im Kontext von KI?

- Block B - Ist-Zustand & Wahrnehmung
  1. Nennen Sie 2–3 konkrete KI-Anwendungsfälle (Zweck, Nutzer:innen, Daten).
  2. Wie werden diese initiiert, freigegeben, betrieben (Gremien, Policies, Freigaben, Monitoring)?
  3. Was läuft gut – und wo hakt es typischerweise?
- Block C - Anforderungen & Governance-Bedarf
  1. Was sind aus Ihrer Sicht die wichtigsten Anforderungen an eine gute Governance von KI?
  2. Welche Mindestprozesse/Entscheidungspunkte brauchen wir (vor Start, vor Go-Live, im Betrieb)?
  3. Welche Nachweise/Metriken/Dokumente bräuchten Sie für ein „Go“?
  4. Wer sollte aus Ihrer Sicht eingebunden sein (z.B. Fachbereichte, IT, Datenschutz, Geschäftsführung)?
- Block D - Risiken & Herausforderungen
  1. Welche Risiken sehen Sie im Zusammenhang mit KI aus Ihrer fachlichen Perspektive?
  2. Wo sehen Sie potenzielle Zielkonflikte (z.B. zwischen Datenschutz, Security und Innovationsfähigkeit)?
  3. Was müsste vermieden werden, damit eine Governance-Struktur tatsächlich funktioniert?
- Block E - Lieferkette & GPAI
  1. Wie gehen Sie mit Anbieterdokumentation (Model Cards, Datenherkunft, Intellectual Property (IP)) um?
  2. Was brauchen Sie von Anbietern/IT/Prozessverantwortlichen, um Entscheidungen treffen zu können?
  3. Erfahrungen mit Generative-AI-Tools: Kennzeichnung, Rechte, Informationspflichten, Vertragsklauseln?
- Block F - Ressourcen, Kompetenzen & Kultur
  1. Wo fehlen Ressourcen/Kompetenzen (z. B. Metriken, Tooling, Schulung, Ops)?

2. Welche Schulungen/Guides/Checklisten würden helfen?
3. Was sollte vermeidbar sein, damit Governance nicht blockiert?

- Rollenspezifische Vertiefung
  - Für CIO/Head of IT
    * Wie sollte das Zusammenspiel zwischen IT, Fachbereichen und Governance bei KI aussehen?
    * Wo sehen Sie die Rolle der IT im Rahmen eines AI-Governance-Modells?
  - Für CISO/IT-Security
    * Welche spezifischen Bedrohungen oder Schwachstellen im Kontext von KI sehen Sie aus Security-Sicht?
    * Gibt es technische Mindestanforderungen, die erfüllt sein müssen, bevor KI-Lösungen eingeführt werden?
  - Für Datenschutzbauftragte
    * Welche datenschutzrechtlichen Herausforderungen sehen Sie bei KI-Anwendungen?
    * Gibt es aus Ihrer Sicht Fallstricke bei der Bewertung von Transparenz, Zweckbindung oder Datenminimierung?
  - Für Compliance / HR (optional)
    * Welche Anforderungen entstehen aus Sicht von Unternehmensrichtlinien, Ethik oder Personalentwicklung im Umgang mit KI?
- Abschlussfragen
  - Gibt es noch Aspekte, die Sie für besonders relevant halten, die wir noch nicht angesprochen haben?
  - Dürfte ich Sie ggf. bei Rückfragen im späteren Verlauf nochmal kontaktieren?

B.2 Interview 1 (CIO, via Teams)

▶ **Interviewer** Vielen Dank, dass Sie sich Zeit für das Interview genommen haben. Das Ziel ist es, Ihre Perspektive auf die Governance von Künstlicher Intelligenz im Unternehmen zu verstehen. Die Ergebnisse werden anonymisiert und ausschließlich im Rahmen meiner wissenschaftlichen Seminararbeit verwendet. Das Interview dauert circa 30 bis 45 Minuten, je nachdem, wie schnell wir sind.

◀ **CIO** Sehr gern.

▶ Wie sieht Ihre aktuelle Rolle und Verantwortung im Unternehmen aus?

◀ Meine Rolle ist CIO der [Division] im Unternehmen [Unternehmen] und meine Verantwortung ist, aus noch lokalen IT-Departments eine globale IT zu formen und damit die IT in sämtlichen Ländern und Geschäftsbereichen der [Division] zu verantworten.

▶ Inwiefern haben Sie derzeit Berührungspunkte mit dem Thema Künstliche Intelligenz?

◀ In mehrfacher Hinsicht. Seit bestimmt anderthalb Jahren gibt es aus diversen Nachbarabteilungen Rückfragen, wann wir KI einsetzen können und wie sie uns helfen kann. Außerdem ist die IT in einer KI-Testgruppe und in einem KI-Gremium Mitglied, um die ersten Schritte strukturiert und kontrolliert hinsichtlich KI bei [Unternehmen] zu orchestrieren, zumindest in der [Division].

▶ Welche Entwicklungen oder Herausforderungen beobachten Sie im Unternehmen oder in Ihrer Funktion im Kontext von KI?

◀ Die größte Herausforderung ist vermutlich das Erwartungsmanagement: Mit KI wird unwahrscheinlich viel verbunden, sodass wir über systemische, prozessorale oder reifegradbedingte Schwächen hinwegsehen und hoffen, dass KI das schon richten wird. Dieser Erwartungshaltung müssen wir begegnen. Außerdem mussten wir uns zunächst mit Governance und Richtlinien beschäftigen, um das Ganze kontrolliert und strukturiert zu ermöglichen. Ich finde es gut, dass sich unser Unternehmen dem Thema KI nicht verschließt, es aber professionell aufnimmt.

▶ Gehen wir zum nächsten Block, Ist-Zustand und Wahrnehmung. Nennen Sie mir bitte zwei bis drei konkrete KI-Anwendungsfälle.

◀ Die, die de facto umgesetzt wurden oder angestrebt werden?

► Je nachdem.

◄ Konkret: der Anwendungsfall Microsoft Copilot aus dem Microsoft-365-Bereich, den ich gerade erst einmal als eine Art persönlichen Assistenten sehe. Das wird an vielen Stellen gefordert und könnte eine Hilfestellung sein. Darüber hinaus gibt es weitere, aber noch nicht näher spezifizierte Anforderungen, beispielsweise aus dem Finance-Bereich, vermutlich basierend auf Dynamics 365. Die Plattform bietet viele Möglichkeiten, wo KI angreifen kann, aber schlussendlich muss es konkrete Use Cases geben. Wir können nicht einfach sagen: „Wir schalten KI an“ und damit ist der Finanzbereich effizienter und die Qualität höher. Es muss Anforderungen geben, etwa im Order-to-Cash-Prozess oder Ähnliches, wo wir uns eine KI-Funktionalität vorstellen, die etwas beschleunigt, die Qualität verbessert, vielleicht ein Vier-Augen-Prinzip ersetzt. Im Bereich M&A hoffe ich, dass wir uns nicht verleiten lassen, dem jetzigen Stand der KI zu vertrauen und M&A-Aktivitäten rein darauf zu basieren oder Entscheidungen ausschließlich auf KI-Output zu stützen. KI in Form von Copilot ist einigermaßen verständlich und nahbar und hat direkte Berührungspunkte mit Endanwendern. Ein zweiter Schritt wird sicher KI im Finance/Controlling sein, aber da brauchen wir noch Zeit.

► Wie werden die Anwendungsfälle initiiert, freigegeben oder betrieben?

◄ In circa 14 Tagen wird [Unternehmen] eine Richtlinie erlassen, wie es zu Anwendungsfällen hinsichtlich KI kommen kann. Es kann nicht einfach umgesetzt werden, sondern wird in einem KI-Gremium, das sich aus diversen Abteilungen zusammensetzt -– beispielsweise Datenschutz, IT-Security etc. –- vorgelegt und dann freigegeben, sodass es umgesetzt werden kann. Gleichzeitig verlangt die Richtlinie beispielsweise eine Beschreibung des Use Cases und dass Trainings angeboten werden. Das passt zu der schon angesprochenen strukturierten und kontrollierten Vorgehensweise.

► In dem Kontext: Was läuft gut und wo hakt es typischerweise?

◄ Gut läuft meines Erachtens, dass wir an dem Punkt angekommen sind, an dem sich das Unternehmen dem Thema KI widmet und eine Richtlinie erarbeitet hat, die in Kürze vorgestellt wird. Damit haben wir einen Prozess, der den Einsatz ermöglicht –- dort, wo er unter Datenschutzgesichtspunkten etc. auch erlaubt ist. Typische Haken sind das Change-Management und -– wie bei allem -– Dokumentations- und Abstimmungsaufwände, um diese Funktion in unserer Division anbieten zu können. Zusätzlich ist es

eine Herausforderung, die angefragten Use Cases im Hinblick auf Datenschutzkonformität etc. überhaupt zu evaluieren. Oft sind wir bei Cloud-Services unterwegs, wo wir nicht hinter die Kulissen schauen können. Wir müssen uns darauf verlassen, dass die Datenverarbeitung in Europa stattfindet oder unsere Daten nicht zum Training der KI-Engines herangezogen werden. Dieser „Dunkelbereich“ bleibt, weil es nicht on-prem betrieben wird, sondern überwiegend in der Cloud. Damit müssen wir umgehen und hoffentlich dem vertrauen, was die Dienstleister -– überwiegend Microsoft –- zur Verfügung stellen.

► Weiter in den Bereich Anforderungen/Governance-Bedarf: Was sind aus Ihrer Sicht die wichtigsten Anforderungen an eine gute Governance von KI?

◄ Zunächst eine grundsätzliche Offenheit. Ohne Kontrolle, ohne Governance besteht die Gefahr einer Schatten-IT für KI. Vieles ist nur einen Klick entfernt -– freie Derivate im Browser -– und das lässt sich nicht vollständig technisch unterbinden. Wenn ich eine Eingabemaske nutze, um z. B. ChatGPT Geschäftsdaten anzuvertrauen oder mir Code generieren zu lassen, kann das gefährlich sein. Deshalb begrüße ich, dass wir eine entsprechende Governance aufsetzen und damit zeigen, dass wir nicht blocken wollen. Es muss ordnungsgemäß laufen -– im Hinblick auf Security, Datenschutz etc. –- und kein lähmender Prozess sein, sondern eine geordnete Governance, die Nutzung ermöglicht, Hilfestellung leistet und sicherstellt, dass wir uns gesetzlich nicht in Felder begeben, die schaden könnten. Das Ganze muss in der Corporate IT umgesetzt werden: Prozesse zum Genehmigen, Umsetzen, Kontrollieren und Integrieren von KI sind nicht losgelöst, sondern müssen verankert sein und entsprechend hoch aufgehängt werden.

► Welche Mindestprozesse oder Entscheidungspunkte brauchen Sie, zum Beispiel vom Start, über die Freigabe bis zum Go-Live und Betrieb?

◄ Zunächst die Anforderungen in Form einer beschriebenen Use-Case-Beschreibung, oft aus dem Business – bleiben wir beim Beispiel Finance. Jemand Fachkundiges muss beschreiben, wo KI helfen soll: Dunkelverarbeitung, Report-Erstellung oder Ähnliches. Dann das Entscheidungstor: Entweder wird der Use Case abgelehnt oder darf umgesetzt werden. Dabei spielen Themen wie Datenschutz (Auftragsverarbeitung), IT-Security, Datenhaltung, Kosten, technologische Umsetzbarkeit und Architektur-Fit eine Rolle. Kommt es zu einem PoV (Proof of Value) und Integrationsaufwand, ergeben sich Projekte, die orchestriert und strukturiert angegan-

gen werden. Am Ende wollen wir sagen können: Diese KI-Anforderung wurde nach bestem Wissen und Gewissen mit unseren Demand- und Projektmanagement-Prozessen sowie unseren IT-Security-Prozessen umgesetzt. Diese Lösungen müssen fortlaufend kontrolliert werden – etwa wenn der Anbieter sagt, er verlagert von Europa nach Amerika oder Asien, weil es dort günstiger ist; das hätte Auswirkungen auf unser vorheriges Approval. Vor der produktiven Nutzung müssen die Endanwendergruppen durch Trainings an die Lösung herangeführt werden, es braucht entsprechende Dokumentation auch für den Datenschutz. Es gibt einige Qualitätsparameter, die erfüllt sein müssen, damit wir live gehen können.

► Welche Nachweise, Metriken oder Dokumente bräuchten Sie, um ein „Go“ geben zu können?

◄ Eine Use-Case-Beschreibung und aus jeder involvierten Funktion im KI-Gremium ein klares „Daumen hoch“ oder „Daumen runter“. Wenn z. B. IT-Security keine Bedenken hat, weil Verschlüsselungsprotokolle eingehalten werden und die Schnittstelle architektonisch passt, der Datenschutz aber sagt: „Das geht nicht, weil außerhalb der EU/EWR“, reicht dieses Veto. Es braucht also ein einstimmiges Approval, damit wir umsetzen. Nach der schriftlichen Darstellung des Anwendungsfalls braucht es schriftliche Stellungnahmen aller involvierten Abteilungen, ein gemeinsames Tool für die Nachhaltung und gegebenenfalls die Einbindung der Demand- und Projektmanagement-Prozesse mit entsprechender Dokumentation. Für den späteren Live-Betrieb oder die Übergabe an den Betrieb braucht es Dokumentation und eine benannte verantwortliche Person – hier: eine KI-Verantwortliche Person –, die beurteilen kann, wenn sich signifikant etwas ändert, etwa eine Verlagerung der Engine in eine Region, die wir nicht sehen wollen.

► Wer sollte aus Ihrer Sicht eingebunden sein – Fachbereiche, IT, Datenschutz, Geschäftsführung?

◄ Für die grundlegende Richtlinie – wie in unserem Fall – das Compliance-Board mit Vorstand. Das muss pro Land passieren, da es unterschiedliche Anforderungen an KI, Datenschutz und Governance geben könnte, auch wenn wir überwiegend in der EU sind. Grundsätzlich: der Fachbereich, denn nur er kann seine Prozesse verstehen, dokumentieren und verbessern. KI ist aus meiner Sicht eine IT-Funktionalität, also ist IT involviert – inklusive Security, Architektur, Governance. Bei größeren Vorhaben kann es in Richtung Projektmanagement gehen, am Ende in den Betrieb und

Support; wenn on-prem gehostet wird, auch Infrastruktur. Also große Teile der IT können involviert sein. Darüber hinaus Datenschutz/Compliance. Je nach Fall brauchen wir Trainingsexperten, Kommunikation/Marketing und ggf. jemanden für Audits oder Wirtschaftsprüfergespräche, um KI-gestützte Funktionen zu erklären. Von Anwendungsfall zu Anwendungsfall muss man entscheiden; der Kern sind IT, Fachbereich und Datenschutz.

► Weiter zum Thema Risiken und Herausforderungen: Welche Risiken sehen Sie im Zusammenhang mit KI aus Ihrer fachlichen Perspektive?

◄ Wie vorhin angesprochen: falsche oder überzogene Erwartungshaltungen, befeuert durch Marketing und den allgegenwärtigen KI-Diskurs. Es vergeht kein Tag, an dem nicht auch Nicht-IT-ler mit Buzzwords wie AI/KI, Large Language Models, GPT etc. in Berührung kommen. Smartphone-Hersteller, Microsoft, Einkaufsportale – alle werben mit KI; dadurch entsteht der Eindruck einer „eierlegenden Wollmilchsau“. Das ist aktuell nicht der Fall. Ein weiteres Risiko ist die Umsetzungserwartung in einer „supermodernen“ Welt vernetzter Systeme mit geringer Komplexität; tatsächlich sind Landschaften oft heterogen und Integration ist anspruchsvoll. Drittens: unkontrolliert auf den Zug aufspringen, mit Risiken für Kostenkontrolle und Change. Ohne Richtlinie droht ein unkontrollierter Blumenstrauß an Lösungen, inklusive solcher, die wir wegen Sicherheit/Datenschutz gar nicht nutzen dürften. Die Richtlinie adressiert das, ausschließen kann man es nicht – ein Restrisiko bleibt.

► Wo sehen Sie potenzielle Zielkonflikte, z. B. zwischen Datenschutz, Security und Innovationsfähigkeit, oder zwischen IT und Fachbereichen?

◄ Zwischen Datenschutz und IT sehe ich grundsätzlich keinen Widerspruch, wir haben ein gutes gemeinsames Verständnis. Datenschutz wird manches strenger sehen, auch testweise. Ein Konflikt entsteht, wenn Anfragen abgelehnt werden. Dann kommt schnell der Vergleich: „Warum geht das anderswo?“ Gründe können EU-Recht, Altsysteme oder Komplexität sein. Weitere Konflikte können entstehen, wenn wir über Effizienzgewinne durch KI reden: Welche Auswirkungen hat das auf die Belegschaft? Andere Unternehmen berichten von Einsparungen; das birgt Konfliktpotenzial.

► Was müsste vermieden werden, damit eine Governance-Struktur tatsächlich funktioniert?

◄ Es darf keinen Weg links und rechts an der Governance vorbei geben und es braucht ein breites, offenes Verständnis für KI und ihre Herausforderungen im Unternehmenskontext. Governance ist zwingend notwendig.

▶ Zum vorletzten Block: Lieferkette und General-Purpose-/Gen-AI. Wie gehen Sie mit Anbieterdokumentation (Model Cards, Datenherkunft) oder Intellectual Property um?

◀ Gute Frage. Ganz grundsätzlich: Was für uns gilt, muss für unsere Partner ebenfalls gelten. Wenn wir mit jemandem zusammenarbeiten, der nachweislich KI einsetzt, sollte das dokumentiert sein – Verarbeitung nach unseren Richtlinien, IT-Sicherheit gebend wie nehmend. Entscheidungen in der Lieferkette sollten nicht komplett der KI überlassen werden; die KI arbeitet für uns, aber die Entscheidungshoheit liegt bei uns und den Partnern. Da sind wir noch ein Stück entfernt.

▶ Was brauchen Sie von Anbietern (extern) oder Prozessverantwortlichen (intern), um Entscheidungen treffen zu können?

◀ Dokumentation: Welche Daten werden wo verarbeitet, welchem Rechtsrahmen unterliegt die Verarbeitung? Wo findet die Datenhaltung statt – EU-/EWR? Können wir Regionen wählen? Können wir bestimmen, welche Daten verarbeitet werden und welche nicht? Können wir das auditieren, wird es dokumentiert? Wie sieht das Änderungsmanagement aus und welche Auswirkungen haben Änderungen (Engine erweitert/eingeschränkt)? Was passiert mit Daten – insbesondere kein Training mit unseren Daten im professionellen Kontext –, welche Löschfristen gelten, wie können wir konfigurativ einwirken? Für KI-Lösungen ist das ein ganzer Blumenstrauß an Informationen, die ich brauche, um abzuwägen, ob ich intern genehmigen, vertrauen und am Ende betreiben kann. Es nützt nichts, 2025 etwas zu genehmigen und danach keine Einsicht mehr zu haben, was wo wie verarbeitet wird und wie Änderungen aussehen.

▶ Dankeschön. Welche Erfahrungen haben Sie mit generativen-AI-Tools in Bezug auf Kennzeichnung, Informationspflichten, Vertragsklauseln?

◀ Bis jetzt keine.

▶ Gut, dann zum Block Ressourcen, Kompetenzen und Kultur: Wo fehlen Ressourcen oder Kompetenzen, etwa Tooling oder Schulungen?

◀ Ganz grundsätzlich – ich spreche für IT, glaube aber, es gilt fürs ganze Unternehmen – sind wir an einigen Stellen nicht auf einem Level der Prozess- und Dokumentationsreife, das nötig ist. In der IT gelten die gleichen Punkte. Wir verbessern uns im Zuge einer IT-Transformation, um prozessstärker zu werden und uns Lösungen professionell widmen zu können. An

Kompetenzen fehlen Digitalisierungs-/KI-Treiber nicht nur in der IT, sondern auch im Business, etwa Finance oder Controlling, um mit KI warm zu werden und Anforderungen beschreiben zu können. Gut ist, dass sich das Unternehmen dem Themengebiet widmet; dedizierte Rollen gibt es aber noch nicht – irgendwo muss man anfangen.

► Welche Schulungen, Guides oder Checklisten würden helfen?

◄ Zunächst unsere Richtlinie, die wir in Kürze verabschieden – fundamental, um den Rahmen zu legen. Dann lösungsspezifische Trainings: Wie nutze ich ein Tool wie Copilot? Wie integriere ich es in den Alltag? Später, für KI im Finanzbereich: Was ist zu beachten, wie gehe ich damit um? Grundsätzlich fände ich auch ein generelles Training analog zu Datenschutztrainings sinnvoll, um Risiken von KI aufzuklären – eine möglichst objektive Darstellung mit Vorteilen (Unterstützung im Alltag, Effizienz, Qualität) und Risiken (Fehlentscheidungen auf falschen Daten, Verlust wertvoller Informationen). So versteht jeder KI besser als vielleicht aus dem privaten Umfeld.

► Was sollte vermieden werden, damit Governance nicht blockiert?

◄ Eine grundsätzlich ablehnende Haltung. Das sehe ich aktuell nicht, denn alle involvierten Bereiche hinterlassen einen engagierten, wohlwollenden Eindruck. Wenn ich sehr ablehnend reagiere, wirble ich den Stellenwert der Governance durcheinander – das darf nicht passieren. Das heißt nicht, dass alles genehmigt werden darf, vielmehr braucht Governance ein klares Mandat. Wichtig ist, dass Governance etabliert ist, feste Bestandteile hat, regelmäßige Aufwände einkalkuliert und die entsprechenden Kapazitäten vorhanden sind – in Zusammenarbeit entlang von Prozessen, die nach und nach geschärft werden. In einem guten Business-IT-Alignment kann das sehr zielführend sein.

► Zum letzten Teil, etwas spezifischer zu Ihrer Rolle: Wie sollte das Zusammenspiel zwischen IT, Fachbereichen und der Governance beim Thema KI aussehen?

◄ Sehr offen und regelmäßig, mit klarer Darstellung, warum es Governance gibt und warum ein KI-Gremium Anwendungsfälle genehmigt oder verneint. Es darf keine Einbahnstraße sein, sondern ein Dialog. Nicht nur der Fachbereich soll als Anforderer agieren und Hürden nehmen; auch die IT sollte proaktiv Impulse geben – wenn beispielsweise [Suite/Plattform] etwas Neues bietet –, auf den Fachbereich zugehen und als Türöffner wirken. Das geht nur im gemeinsamen Dialog.

▶ Wo sehen Sie die Rolle der IT im Rahmen eines AI-Governance-Modells?

◀ Am Ende ist IT der Betreiber von Lösungen – auch von KI-Lösungen, egal ob on-prem (Server-, Netzwerk-, Applikations-Landschaft) oder als Subscription. Die IT trägt die Verantwortung, diese Lösungen datenschutz- und sicherheitskonform zu betreiben und mit einem Service zu versehen, der den internen Endanwendern zur Verfügung steht. Dafür braucht es innerhalb der IT eine entsprechende interne Governance: Zusammenarbeit der notwendigen Departments, klare Produkte, Einhaltung der Prozesse, Gremien und Entscheidungen. Governance muss auch die IT selbst regelmäßig „abholen“, was es heißt, KI-Systeme auszuwählen, freizugeben, zu betreiben und permanent zu kontrollieren. Das sehe ich als Notwendigkeit – insbesondere im Hinblick auf IT.

▶ Vielen Dank. Gibt es sonst noch Aspekte, die für Sie besonders relevant sind und die wir nicht angesprochen haben?

◀ Mich treibt um, wie ich künftig die Übersicht behalte, wo KI eingesetzt wird, wo sie wirkt und wo ich eingreifen muss: bei Qualität, Kosten, zu komplexen Anwendungsfällen oder wenn Sachbearbeiter nicht mehr sinnvoll interagieren können. Wann besteht Notwendigkeit zum Handeln? Vorne haben wir die Genehmigung eines Anwendungsfalls, aber was passiert hinterher im Lifecycle? Welche Merkmale zeigen mir – aus IT-Security-, Endanwender-, Fachabteilungs- oder Datenschutzsicht –, dass ich aktiv werden muss? Wie sieht der Review-Prozess aus? Der kann auch bedeuten, eine KI-Unterstützung im Finanzbereich zurückzunehmen, wenn sich signifikant etwas ändert oder die Qualität nicht mehr stimmt. Wie komme ich in einen Prozess, der sicherstellt, dass alles stabil läuft, ich mich darauf verlassen kann und Kostenkontrolle habe?

▶ Dürfte ich Sie gegebenenfalls bei Rückfragen später noch einmal kontaktieren?

◀ Auf jeden Fall.

▶ Gut, Dankeschön.

◀ Bitte sehr.

B.3 Interview 2 (Head of IT-Security, vor Ort)

► **Interviewer** Vielen Dank, dass du dir die Zeit für das Interview nimmst. Das Ziel ist es, deine Perspektive auf die Governance von Künstlicher Intelligenz im Unternehmen zu verstehen. Die Ergebnisse werden anonymisiert und ausschließlich im Rahmen meiner wissenschaftlichen Seminararbeit verwendet. Das Interview dauert circa 30 bis 45 Minuten.

◄ **Head of IT-Security** Dann lass uns anfangen.

► Wie sieht deine aktuelle Rolle und Verantwortung im Unternehmen aus?

◄ Ich verantworte, gemeinsam mit meinem Team, die Informationssicherheit im Unternehmen. Zumindest die Verantwortung für unsere Divison. Das umfasst klassiche IT-Security Aufgaben, wie Network Security, Firewalling, Incident Responses aber auch die zunehmende Integration von Cloud-Diensten und modernen Technologien, wie eben auch KI. Zudem bin ich als Teil des gegründeten KI-Gremiums für die Einführung von KI-Systemen mit verantwortlich.

► Inwiefern hast du derzeit Berührungspunkte mit dem Thema Künstliche Intelligenz?

◄ Wie bereits erwähnt, als Teil des KI-Gremiums beschäftigen wir uns mit dem Thema KI. Dort werden nicht nur Regularien festgelegt, sondern auch die Bewertung und Freigabe von KI-Systemen erfolgt dort.
Und natürlich einfach aus Interesse mit KI schon mal ein bisschen beschäftigt. Aber da gibt es definitiv Leute, die damit viel, viel mehr machen als ich. Mich nervt das Thema an vielen Stellen, weil viele davon sich mehr versprechen, als aktuell die KI leisten kann. Was teilweise dazu führt, dass Leute einfach ellenlange Texte schreiben, die dann kein Mensch mehr liest und sich die Leute dann von KI zusammenfassen lassen. Und da bin ich manchmal unschlüssig, ob da die, die die Informationen wirklich noch von A zu B kommen, so wie sie sollten. Ich muss aber auch sagen, dass ich für ein paar Anwendungsfälle jetzt mal in ChatGPT genutzt habe, privat und da doch an einigen Stellen überrascht war, wie gut die Ergebnisse waren. Als Beispiel jetzt. Wir kriegen eine PV Anlage. Da ging es zum Beispiel darum, wie groß müssen die Leerrohre sein? Die hatten uns mitgeteilt, was für ein Querschnitt die Kabel hatten und wie viele Kabel. Und dann habe ich einfach mal ChatGPT dazu befragt und da konnte man ziemlich schnell sagen, wie groß die Leerrohre sein müssten. Also für so Recherchedinge ist das auf jeden Fall super, super interessant und super hilfreich.

► Welche Entwicklungen oder Herausforderungen beobachtest du im Unternehmen oder in deiner Funktion im Kontext von KI?

◄ Herausforderungen? Auf jeden Fall, was ich gerade schon sagte, dass das einfach die Erwartungen so weit auseinandergehen und teilweise auch unrealistisch sind, dass man da den Leuten einfach klar machen muss. Was können sie erwarten und was können sie nicht erwarten? Auf der anderen Seite ist ein bisschen die Herausforderung auch, dass jetzt alle Hersteller und sowas überall KI dran schreiben und alles wird besser. Und auch da muss man irgendwie einordnen. Ja, früher waren es irgendwelche Scripte und Automatisierungen, die da liefen. Heute heißt alles KI steckt wahrscheinlich in vielen, jetzt mittlerweile auch in LLMs oder sowas dahinter. Hat für uns jetzt aktuell praktisch noch keinen großen oder kein großes Gewicht in unserer Arbeit. Wir haben jetzt vor kurzem auch mal mit einem externen Unternehmen Microsoft Security CoPilot und demonstrieren lassen. Da sind wir wieder beim Thema Recherche. Super interessantes Thema, weil uns das wirklich Zeit sparen kann. Weil wenn wir mal ein kompromittiertes Konto haben und ich gucke mir das an, dann brauche ich dafür eine Stunde oder zwei. Und der Security Copilot kann einem diese Antworten, die man sonst so manuell raussuchen muss halt in zwei Minuten oder sowas geben. Da sparen wir natürlich massiv Zeit ein. Oder könnten wir, wenn wir das Tool einführen.
Einigen nutzen das einfach, um einfach Massen an Text zu generieren, der auch deutlich kürzer ausreichen würde. Und das stielt halt Leuten Zeit. Und da bin ich dann auch nicht bereit mehr dass das irgendwie zu lesen, wenn das immer wieder passiert und es einfach nur aufgeblähter Text ist.

► Dann gehen wir so ein bisschen in Richtung Ist-Zustand und die Wahrnehmung von KI auch. Kannst du mir so 2 bis 3 konkrete KI Anwendungsfälle im Unternehmen nennen?

◄ Ich denke was Anwendungsfall Nummer eins aktuell ist wirklich Recherche, Informationen zusammenfassen, aufbereiten. Und das ist durch die Bank. Ob das jetzt für die Administratoren Logfiles sind oder irgendwelche Internetrecherchen für keine Ahnung was auch immer, gibt es wahrscheinlich Millionen Fälle. Jetzt speziell für das Unternehmen. Ich glaube was was bei uns im Unternehmen auf jeden Fall super sinnvoll wäre, wäre alles in Richtung Predictive Maintenance. Da ist glaube ich KI wirklich auch ein Ding, was einfach wenn die Hersteller 100.000 Maschinen im Einsatz haben und da KI drüberlaufen lassen um die Daten auszuwerten kann man da glaube ich super sinnvolle Sachen mit machen.

► Wie werden dann diese Anwendungsfälle initiiert, freigegeben und auch betrieben?

◄ Aktuell gar nicht, aber da arbeiten wir dran. Ich war jetzt schon mal auf das auf das KI Gremium eingegangen. Wir sind da jetzt kurz davor eine Richtlinie zu verabschieden. Und dann gibt es einen Freigabeprozess, wo die verschiedenen Abteilungen wie Datenschutz, Sicherheit und weitere, das ganze reviewen und freigeben. Und dann werden wir, denke ich in relativ kurzer Zeit einige KI Anwendungsfälle einführen, freigeben und dann auch leben, denke ich.

► Was läuft gut und wo hakt es typischerweise bei dem Thema KI und auch bei den Anwendungsfällen?

◄ Also jetzt aktuell ist es so, dass ich ja gerade schon sagte, überall steht jetzt KI dran, mittlerweile. Wahrscheinlich schon einiges an KI-Diensten Services, wie man das nennen will, im Einsatz sein dürfte unreglementiert. Wir als als alte Sicherheitsabteilung können da sperren. Aktuell alles, was unsere Firewall so erkennt an KI Diensten und was nicht freigegeben ist. Es gibt auch natürlich genug Dienste, die irgendwie freigegeben sind, wo KI mit drinsteckt, die wir aktuell dann nicht reglementieren oder nicht reglementieren können. In Zukunft? Worauf will ich hinaus? Wir bekommen natürlich eine ganze Menge Anfragen aktuell. „Ich komme auf diesen Dienst nicht drauf.“ Wo wir dann aktuell immer sagen ja, ist aktuell nicht freigegeben, kommt bald. Wo dann aber durchaus schon ziemlich Druck gemacht wird, dass die diesen Dienst jetzt brauchen. Aber da haben wir aktuell den Vorteil, dass wir einfach auf die Datenschutzabteilung zeigen können und die haben es uns quasi verboten. Von daher macht es das leicht. Aber die Diskussion muss man halt regelmäßig führen. Ein aktuelles Beispiel war zum Beispiel irgendein Adobe Dienst, um Fotos zu bearbeiten, um damit die Bilder retuschieren zu können. Es ging nicht darum, neue Bilder zu erstellen, wo wir dann direkt wieder beim Thema geistiges Eigentum wären. Sondern es ging wirklich um Bearbeiten auf Aufhellen, Farbskala, anpassen, was weiß ich, was man mit den Bildern machen kann. Aber auch die haben wir vertröstet auf auf den Stand der KI Richtlinien.

► Okay, dann gehen wir ein bisschen weiter in Richtung Anforderungen und Governancebedarf. Das heißt aber, viele Sachen kommen vielleicht noch mal wieder als Fragen jetzt, die du vielleicht indirekt schon beantwortet hast. Was sind aus deiner Sicht die wichtigsten Anforderungen an eine gute Governance von KI?

◀ Ich glaube, A und O ist den Leuten bewusst zu machen, welche Daten dürfen sie von der KI verarbeiten lassen und welche nicht. Welche dürfen Sie in ich sag mal öffentliche KI Systeme eingeben und vielleicht speziell von uns betriebene KI Systeme. Ein Beispiel war, ich weiß nicht mehr, wer es sagte. Es war in irgendeiner Runde, da sagte jemand „Ja, wir könnten KI super für Merger and Acquisitions gebrauchen“ und dafür wollten sie Chatgpt nutzen. Da ist es glaube ich wichtig, den Leuten bewusst zu machen, dass wenn sie jetzt suchen, nach welche Firma können wir jetzt kaufen in Zukunft. Dass das halt Daten sind, die wir vielleicht nicht anderen Firmen zur Verfügung stellen sollten. Ich glaube, da ist es ganz wichtig, die Leute zu schulen und zu trainieren, um das und sich dessen bewusst zu werden.
Genau. Es muss ein klares Konzept geben. Was? Wo sich was? Sich die Leute angucken können. Was dürfen wir da reinfügen und was nicht? Und es muss aus meiner Sicht ja da entsprechend Schulungen zu geben. Das ist natürlich wichtig.

▶ Okay. Welche Prozesse oder Entscheidungspunkte bzw Entscheidungsszenarien vielleicht auch? Braucht ihr denn also für den Start überhaupt darüber zu sprechen für den Go Life vielleicht, später dann aber auch den Betrieb. Wie sieht es da aus?

◀ Also aus IT-Sicherheitssicht spielt KI jetzt noch keine so große Rolle. Es wird immer viel darüber geredet, dass die Angreifer jetzt KI nutzen. Und ja, das stimmt schon, aber das ist jetzt nicht der Hauptteil der der Angriffe, den wir so sehen. Also es ist nach wie vor verlässlich vernachlässigbar. Ein paar Emails sind jetzt mit ein paar weniger Rechtschreibfehlern und Grammatikfehlern ja das schon, so Phishing Mails. Von daher sind da jetzt Entscheidungspunkte für uns, was die Richtung angeht nicht nicht so entscheidend. Wenn wenn wir so Dienste prüfen. Ist es immer sehr schnell dieser Grat zwischen Wo hört IT-Sicherheit auf, wo fängt Datenschutz an? Das ist dann sehr häufig ein Datenschutz Thema. Für uns ist wichtig, dass wir zuverlässig mitgeteilt bekommen, was können wir den Leuten freischalten und erlauben und was nicht. Das ist für uns eigentlich aktuell das Wichtigste in diesem Bereich.

▶ Welche Nachweise, Metriken oder Dokumente braucht ihr denn für um Go zu geben? Sozusagen für eine KI? Also wann kann die denn dann verwendet werden? Aus IT-Sicherheit Sicht?

◀ Also aus unserer Sicht reicht reicht irgendein Dokument, ob wir das jetzt als Service Request oder sonst was umsetzen. Wenn da drin steht Services

freigegeben von allen Beteiligten? Dann reicht uns das. Dann können wir das technisch erlauben. In den Systemen? Ja. Wichtig ist halt die Prüfung. Und bei der Prüfung würden wir dann so Dinge prüfen wie. Wie speichert der Hersteller seine Daten? Wie sichert der das System ab und sowas? Das würden wir bei der Prüfung dann natürlich selbst prüfen. Das ist im Prinzip zur vorherigen Frage. Eine Entscheidung ist natürlich was, was wir selbst prüfen würden. Das machen wir aber jetzt nicht speziell für KI Systeme, sondern das machen wir für alle externen Dienste und Dienste, die wir so einsetzen wollen. Und ja, da geht es hauptsächlich um Zugriffe, Verschlüsselung, Datensicherheit. Wenn das das geklärt ist, ist das für uns in Ordnung.

► Wer sollte denn aus deiner Sicht eingebunden sein in diesen gesamten Prozess der Freigabe des Betriebs auch insgesamt?

◄ Ich fände es da erstmal spannend, wo die die Anfragen überhaupt herkommen. Die müssen ja irgendwie aus dem Unternehmen kommen, aus dem Business. Klar ist Datenschutz ein wichtiger Teil. Wir als Sicherheit sind ein wichtiger Teil, dann die Governance Abteilung, wie auch immer man sie nennen will, die das Ganze dann irgendwie in eine Form gießen muss. Die muss natürlich dabei sein. Ich denke, in der IT gibt es noch ein paar weitere Stellen, die irgendwie, die dann vielleicht den Betrieb übernehmen müssen. Die sollten dabei sein. Die sollten natürlich auch eine Chance haben, da einwirken zu können. Und dann ist es auf jeden Fall wichtig, dass die Firma in irgendeiner Weise dem Ganzen auch zustimmt. Ob da jetzt irgendwie eine Form des Managements mit beteiligt sein muss oder auf welcher Ebene, das lässt sich glaube ich diskutieren. Aber ich denke, das ist auch wichtig, dass das ja von der Firma an sich irgendwie mit mit begutachtet wird.

► Okay, dann gehen wir weiter in das Thema Risiken und Herausforderungen von KI. Welche Risiken siehst du denn im Zusammenhang mit KI aus deiner fachlichen Perspektive auch?

◄ Ein Risiko Nummer eins für mich ist irgendwie Datenabfluss, dass die Leute dort Dokumente, Informationen, Interna oder Geheimnisse reinpacken. Ich sehe jetzt die Chance nicht so groß, dass die Anbieter dieser Systeme irgendwie diese Daten auswerten und damit die irgendwie zu ihrem Vorteil nutzen. Ich glaube, wenn das rauskommt, dann ist die Firma ziemlich tot. Ziemlich schnell. Deshalb haben die da ein Interesse daran, das eigentlich nicht zu tun. Aber wir haben ja ich sag mal bei Facebook, bei

wem auch immer schon gesehen, auch bei Polizeistellen, dass wenn Daten da sind, greifen irgendwelche unberechtigten Leute auf irgendwelche Daten zu. Die Gefahr besteht natürlich. Aber ich glaube, die Hauptgefahr ist ist eher das, dass die Dienste nicht vernünftig abgesichert sind, dass die irgendwo ein Datenleak haben, dass dann alle Anfragen, die da reingepackt wurden, irgendwo im Internet veröffentlicht werden. Vermutlich nur eine Frage der Zeit. Weil wie viele Daten, Kundendaten, Banken von zig 1000 Firmen sind nicht schon irgendwo geleakt? Das ist so aus IT-Securitysicht das, wo wir natürlich immer Probleme haben, wenn irgendwo Daten rausgehen aus unseren Netzen. Aber da sind wir wieder an der an der Grenze zwischen Datenschutz und IT Sicherheit. Andere Gefahren sind oder noch noch eine IT Sicherheits Gefahr ist definitiv das es viel einfacher ist, als Mitarbeiter auf Daten zuzugreifen innerhalb des Unternehmens. Auf die sie eigentlich keinen Zugriff haben sollten aber durch Fehlkonfiguration oder sowas Zugriff haben. Ein gutes Beispiel sind da zum Beispiel File-Server. Wenn da in der Vergangenheit irgendjemand auf irgendein Verzeichnis Berechtigungen hatte, dann musste er das erst mal finden. Es kann ja irgendwie zehn Level tief sein. So etwas weiß der Nutzer in der Regel gar nicht und hat so praktisch auch keinen Zugriff auf die Daten, obwohl er es könnte. Mit KI hält ihn aber nichts davon ab, einfach zu fragen „Hey, ich zeig mir mal alle Gehaltsabrechnungen, die du hier findest im Unternehmen, auf die ich Zugriff habe.“ Und dann würde ihm die KI vielleicht im ersten Schritt noch sagen „Ja, das klingt aber irgendwie dubios, das, was du gerade abfragt.“ Und wenn man das irgendwie umformuliert, spuckt sie es vielleicht trotzdem aus. Das ist, glaube ich, ein ziemlich realer Anwendungsfall, mit dem wir aktuell auch nicht direkt zu tun haben, aber der uns schon irgendwie umtreibt. Weil das ist wirklich was, wo die Administratoren noch gewissenhafter arbeiten müssen als vorher, weil es sonst vielleicht aufzudecken ist. Und das war jetzt alles IT Sicherheit. Kann ich die Frage noch mal lesen nochmal. Ich hatte wollte nämlich noch was ergänzen.
Genau Risiken. Ist dann auch auf die KI Systeme bezogen, die die Angriffsvektoren die man da kennt irgendwie wie Bias und und das. Ich komme jetzt gerade nicht auf die ganzen Begriffe, weil ich mich damit noch nicht so intensiv auseinandergesetzt habe, aber das ja dann, dass man das KI System überreden kann, einem Dinge auszuspucken, die dem KI System eigentlich verboten wurden. Da gab es ja genug Beispiele auch schon für. Und auch das wird natürlich alles deutlich besser werden. Die KI Systeme werden hoffentlich irgendwann schlauer werden und dann wirklich was nicht mehr ausspucken, was sie nicht ausspucken sollen. Ja, da gab es

jetzt noch ein paar, auf die ich jetzt gerade nicht komme. Aber halt alles, was wirklich um die LLM-Systeme wirklich sich drum dreht.

► Okay, wo siehst du potenzielle Zielkonflikte, zum Beispiel zwischen Datenschutz, IT, Security und dann dagegen vielleicht die Innovationsfähigkeit?

◄ Ja. Also KI Systeme und Sicherheit seh ich jetzt nicht so direkt das Konfliktpotenzial aktuell. Bis auf den Anwendungsfall gerade mit, dass man vielleicht Dinge abfragen kann. Treibt uns das nicht so um wie den Datenschutz. Die haben natürlich da wieder auch das Problem, dass sie nicht einschätzen oder nicht kontrollieren können, welche Daten gehen wohin. Und ich denke schon, dass es dass es einige Anwendungsfälle gibt, wo man damit wirklich innovativ sein kann. Bin aber aktuell der Meinung, dass das die Blase einfach viel zu groß ist und die Erwartungen unrealistisch sind. Aber es gibt sicherlich einige Anwendungsfälle, wo man nicht die Innovationsfähigkeit hindern sollte durch irgendwelche Datenschutzgründe oder Sicherheitsgründen, sondern dass man da Wege finden muss oder sollte, das das zu erlauben.

► Okay, was müsste vermieden werden, damit eine Governance Struktur tatsächlich funktioniert?

◄ Ja, ich glaube so eine Governance Struktur ist immer nur so gut wie wie sie in der Praxis gelebt wird. Vermieden werden müssen die Feldwege drumherum sozusagen. Also da kommt es dann wirklich auf die in dem Fall auf uns als IT-Sicherheitsteam an, dass wir nicht auf Zuruf mal eben Dienste freigeben. Aber ich sage mal, das ist was, a haben wir jahrzehntelange Erfahrung, ob das jetzt irgendwelche Internetseiten sind oder irgendwelche KI Dienste. Da sind wir geschult mit umzugehen. Ja, ich weiß nicht. Shadow IT Zählt das dazu? Die hat man ja sowieso mit der Governance nie, nie irgendwie erwischt. Aber ja, das ist glaube ich einfach der Überbegriff für das, was ich gerade meine. Das könnte man ja auch darunter zusammenfassen.

► Jetzt gehen wir ein bisschen weg von dem ganz Theoretischen. Es geht ja immer noch Lieferketten und General Purpose. Wie gehen wir mit der Dokumentation um? Also es gibt ja Model Cards zum Beispiel für KI oder eben auch die Datenherkunft oder Intellectual Property von anderen Personen, die halt eben nicht mehr Teil der KI sind, wo irgendwelche Daten verwendet werden. Wie gehen wir also mit diesen Dokumentationen dazu um?

◀ Das ist wirklich ein Spannendes Thema, glaube ich. Einer der Knackpunkte in dem Ganzen, Was das Thema KI angeht. Weil gerade Intellectual Property ist wirklich spannend, die ich sag mal die großen Konzerne wollen Geld für jedes kleine bisschen. Nutzen aber jetzt alles was frei verfügbar im Internet war, ohne auch nur, so scheint es zumindest einen Gedanken daran zu verschwenden. Wenn man dann liest, dass Facebook bei BitTorrent 100.000 Bücher runtergeladen hat und die einfach in ein System integriert hat, ist das alles so ein bisschen zweifelhaft. Aber da kann ich nicht sinnvoll was zu sagen. Ich sehe das auch als einen der Knackpunkte. Und da müssen wir, glaube ich, als Gesellschaft irgendwie eine Lösung für finden. Das wird sich über die nächsten paar Jahre irgendwie entwickeln. Da bin ich sehr gespannt auf die Entwicklung.

▶ Was braucht denn von Anbietern der IT oder auch Prozessverantwortlichen, um Entscheidungen treffen zu können im Bereich KI?

◀ Ja. Das ist was. Das müssten wir eigentlich in unser in unsere Procurement Dokumente aufnehmen, weil ich glaube, das haben wir aktuell noch nicht. Das wäre echt wichtig. Also wir haben da viel mittlerweile drin, was die Sicherheit angeht. Aber gerade KI wäre glaube ich noch mal ein Thema, was man da aufnehmen sollte, weil wir es ja dokumentieren müssen. Den Einsatz. Ja, ich denke, dass es da auch irgendwie auf auf in Zukunft auf Standard Dokumente und und Zertifizierung wahrscheinlich hinauslaufen wird. Also für Security haben wir da sehr viel, was man einfach über Zertifizierung abfragen kann. Dann weiß man relativ genau, wie sind die abgesichert, was, was für Techniken nutzen die und so? Und ich würde erwarten, dass es für KI wahrscheinlich ähnliche Dinge geben wird in Zukunft. Das wäre zumindest sinnvoll, denke ich.

▶ Welche Erfahrungen hast du mit Gen-AI-Tools, aber eher im Bereich Kennzeichnung, Rechte Informationspflichten, Vertragsklauseln vielleicht auch?

◀ Wenig bis gar nicht. Ehrlich gesagt, glaube ich nicht, dass ich schon irgendwas. Doch ich habe schon mal Sachen gesehen, die als KI Gekennzeichnet waren. Aber es ist wirklich, wirklich vernachlässigbar. Also macht so gut wie niemand.

▶ Jetzt gehen wir zum vorletzten Block. Thema Ressourcen, Kompetenzen und Unternehmenskultur. Wo fehlen denn aus deiner Sicht Ressourcen oder auch Kompetenzen?

◀ Im Unternehmen, bei uns? Schulungen werden gerade aufgebaut über das KI-Gremium. Also wenn wir Dienste nutzen wollen, sollen dazu Schulungen oder müssen dazu Schulungen angeboten werden. Die Frage noch mal. Ich denke, dass es im Business wahrscheinlich sinnvoll wäre, zumindest jemanden zu haben. Oder vielleicht bei uns in der Firma obendrüber, der sich mit dem Thema auseinandersetzt. Also wo könnte man diese Sachen sinnvoll einsetzen? Ich denke für Prozessoptimierung und so, wie wir unsere Maschinen effizienter machen, wenn unsere Prozesse effizienter werden können, dass wir noch mehr aus unseren Rohstoffen rausholen können. Ich glaube, da könnte man das sinnvoll einsetzen. Und ich wüsste nicht, dass wir so eine Ressource haben im Unternehmen, die, die in die Richtung unterwegs ist. Das finde ich sinnvoll. Ich weiß auch nicht, ob wir die Kompetenz im Unternehmen haben Aktuell.

▶ Okay, dann welche Schulungen, Guides oder oder Checklisten würden denn helfen bei dem gesamten Thema?

◀ Ja, genau. Schulungen habe ich vorhin schon was dazu gesagt. Also ich denke, es ist wirklich essenziell wichtig, den Leuten bewusst zu machen, was was mit den Daten passiert, was, was, was sie wo eingeben dürfen. Da ist glaube ich eine Checkliste super sinnvoll. Die wäre da, glaube ich auch im Gremium verabschiedet haben, dass wir sowas erstellen wollen, sodass der User auf einen Blick sehen kann. Okay, ich habe jetzt hier eine Internetseite. Ich weiß nicht, wer wer diesen Dienst irgendwie betreibt. Da sollte ich jetzt vielleicht nicht meine Fragen zur Akquisition, um das Beispiel noch mal aufzubringen stellen. Die könnt ihr besser in unserem Copilot oder was auch immer wir dann einsetzen, gefragt werden.

▶ Was sollte denn vermieden werden, damit Governance nicht blockiert?

◀ Der Prozess muss funktionieren, den wir uns ausdenken. Die Governance darf nicht nicht ausufernd sein. Muss von einem Großteil unserer Mitarbeiter auch auszufüllen sein. Also der der Anfrageprozess von Application oder KI Dienst, darf jetzt nicht ein Studium erfordern. Das sehen wir ja auch bei anderen Service Requests häufig schon, dass die IT da Dinge abfragt, die die Leute gar nicht beantworten können. Die Gefahr sehe ich so ein bisschen bei KI auch, weil weil das sehr technisch ist und vielleicht, wenn wir wieder mal an Prozesssteuerung oder Produktionsanlagen denken, was die Leute so vielleicht gar nicht beantworten können. Da müssen wir, glaube ich, dann Hilfestellung geben für viele Anfragen. Und ansonsten, glaube ich, ist es wichtig, dass wir natürlich die die gesetzlichen Regelungen einhalten. Aber das muss vielleicht auch ausreichen,

um da nicht irgendwie Innovation zu blockieren.

- Jetzt gehen wir mal ein bisschen spezifischer rein. Welche spezifischen Bedrohungen oder Schwachstellen im Kontext von KI siehst du aus Security Sicht? Da hast du teilweise schon ein bisschen beantwortet. Aber einfach noch mal um das aufzugreifen.

- Ja. Also da fällt mir direkt wieder das Beispiel mit dem Server an, wo früher man erstmal wissen musste, wo habe ich überhaupt Zugriff um unberechtigt auf irgendwas zugreifen zu können. Jetzt ist das viel leichter. Ja und wie gesagt, für Angriffe und so wird das von den Sicherheitsherstellern natürlich total aufgeblasen. Aber die Praxis zeigt einfach, dass die Angriffe wirklich vernachlässigbar sind. Also es spielt keine wirkliche Rolle. Es sind immer noch irgendwelche Kiddies, die im Support anrufen und sagen „Hey, ich bin Mitarbeiter, ABC setze meinen MFA und Passwort zurück.„ Oder einfach Leute die auf Phishing Seiten komplett alles eingeben. Das ist das, was mir so einfällt.

- Gibt es technische Mindestanforderungen, die erfüllt sein müssen, bevor die Lösung eingeführt werden.

- Die, also die Datenspeicherung und Datensicherheit muss natürlich gewährleistet sein. Es kommt natürlich immer darauf an, was was für eine Art von Dienst ist. Wenn wir für Recherche und sonst was genutzt wird, können natürlich auch wieder sensible Daten da drin sein und gespeichert werden. Das ist generell ein spannendes Thema. Wie lange werden die Daten gespeichert? Werden die Daten genutzt, um das Modell weiter zu zu optimieren, zu weiterzuentwickeln? Das sind, glaube ich, alles, alles wichtige Dinge, die man zumindest für die Einschätzung des Dienstes wissen muss.

- Das sind so gut wie alle Fragen von mir gewesen. ibt es eigentlich noch Aspekte, die du für besonders relevant hältst, die wir aber noch gar nicht angesprochen haben?

- Was nicht passt zum Thema, passt also zum Thema auf jeden Fall. Ich persönlich sehe die Gefahr, dass da Riesenentöpfe erstellt werden. Und man muss gar nicht so weit in die Vergangenheit gucken, um zu sehen, wie das missbraucht werden kann. Wenn man jetzt Beispiel USA sich anguckt und die noch noch drei Jahre so weitermachen, dann ist es vielleicht auch keine gute Idee, denen irgendwie alles mögliche an Daten zu geben. Aber das ist ja ein gesellschaftliches Thema. Das ist nichts, Was wir jetzt als als Firma technisch irgendwie beschränken können. Ein weiterer Punkt

ist natürlich auch wie weit will man da gehen und wie viele Jobs stehen irgendwann dann auch auf dem Spiel da an der Stelle. Das ist definitiv was. Ich würde jetzt nicht sagen, was mich aktiv beschäftigt, aber schon was ist, wo ich ab und zu mal so drüber nachdenke. Übersetzer brauchen wir bald nicht mehr. Grafikdesigner brauchen wir bald vielleicht auch nicht mehr. Und das kann eine ganz schöne Umwälzung geben.

► Okay, dann danke ich dir. Wenn noch Fragen sind oder so, kann ich dich dann kontaktieren?

◄ Jederzeit gerne.

B.4 Interview 3 (Datenschutzbeauftragter, vor Ort)

► **Interviewer** Danke, dass du dir die Zeit nimmst für das Interview. Erstmal Das Ziel ist es, die Perspektive auf die Governance von künstlicher Intelligenz im Unternehmen zu verstehen. Die Ergebnisse werden anonymisiert und ausschließlich im Rahmen meiner wissenschaftlichen Arbeit verwendet. Das Interview dauert circa 30 bis 50 Minuten. Ich werde das Ganze eben mitschneiden, wie hier schon besprochen. Dann fangen wir erstmal an. Wie sieht deine aktuelle Rolle und Verantwortung im Unternehmen aus?

◄ **Datenschutzbeauftragter** Ich habe hier bei uns im Unternehmen eine Doppelfunktion. Ich bin zum einen Head of Data Protection, das heißt, ich leite die zentrale Datenschutzabteilung. Wir haben aktuell insgesamt zwei Mitarbeiter plus mich in der zentralen Datenschutzabteilung. Und dann haben wir noch ganz viele Datenschutzkoordinatoren in den operativen Bereichen, das heißt auf Gesellschaftsebene und je nach Größenordnung der Gesellschaft haben wir da auch mehrere Datenschutzkoordinatoren im Einsatz. Und in meiner zweiten Funktion bin ich auch Konzern Datenschutzbeauftragter jeder deutschen Gesellschaft. Ja, also das heißt, für alle deutschen Gesellschaften bin ich letztendlich auch in der Verantwortung und in der datenschutzrechtlichen Haftung. Genau das sind meine zwei Funktionen, die ich hier bei der Sache ausführe.

► Okay. Inwiefern hast du Berührungspunkte mit dem Thema künstliche Intelligenz?

◄ Irgendwann wurde mir gesagt, wir wollen das Thema KI bei uns fördern bzw. KI Tools einführen in der Zukunft. Und da das Thema relativ viele ähnliche Mechanismen wie im Datenschutzrecht hat, hat man gesagt da können sie sich dann mal Gedanken zu machen. Mit hat man gesagt, meine ich der Vorstand hat in unserer Compliance Board Sitzung, das ist quasi eine gesonderte Gremium Sitzung, wo wir über Compliance Themen reden. Er hat dann gesagt, da machen Sie sich mal Gedanken, wie sie so eine Governance bei uns im Konzern einmal aufziehen können und dann für die Zukunft KI Tools rechtlich sauber einführen können.

► Welche Entwicklungen oder Herausforderungen beobachtest du im Unternehmen oder deine Funktion im Kontext von KI?

◄ Ja, das ist natürlich eine Frage. Da bräuchte ich eigentlich eine Woche, um die zu beantworten und mehrere Vorlesungen. Also es gibt auf verschiedenen Ebenen Herausforderungen. Vielleicht einmal übergeordnet gibt

es eine gesellschaftliche Herausforderung, glaube ich. Und das ist einmal das Verständnis für das Thema KI. Also wenn man durchs Gebäude rennt und zehn Personen jetzt zum Thema KI fragen würde, würde man 20 Antworten wahrscheinlich bekommen. Jeder hat da mindestens eine Meinung zu und die geht auch komplett auseinander. Selbst wenn man mit Führungskräften redet, kriegt man auch verschiedene Meinungen. Der eine sagt mir, ich bin zu alt für das Thema und nutze es auch nicht. Ich brauche es auch nicht mehr, was auch völlig legitim ist. Und der andere erzählt mir auch, ich kann nachts nicht schlafen, weil ich das Gefühl habe, wenn wir sie nicht einführen, dann verlieren wir den Wettbewerb. Alles ist richtig. Ich glaube, das größte Problem oder die größte Herausforderung ist da, irgendwie ein Konsens zu finden, dass alle verstehen: Okay, das ist überhaupt künstliche Intelligenz. Also es gibt Produkte, die wollen wir einsetzen, können wir es einsetzen. Das heißt, die größte Herausforderung ist aus meiner Sicht das gemeinsame Verständnis für künstliche Intelligenz, auch mit Blick für die unternehmerische Zukunft.
Dann gibt es natürlich ganz viele rechtliche Fallstricke. Völlig klar, da gibt es viele Herausforderungen. Man muss sich quasi jedes Tool einmal individuell angucken. Ja, das heißt, wenn wir am Ende eine Governance ausgestalten, müssen wir auch überlegen: Welche Tools wollen wir einsetzen? Ja, auch mit Blick auf das deutsche Recht sowie auf das europäische Recht. Dann gibt es sicherlich auch technische Herausforderungen. Ich bin jetzt kein Techniker, aber da muss man auch natürlich immer gucken. Im Rahmen eines Proof of Concept funktioniert das ganze Thema. Oft kriegt man ja immer so schöne Werbebroschüren auf Messen. Ja, da werben auch Anbieter. Wir haben die schönsten Tools. Sie können 95 % Ihrer Arbeit, Ihrer täglichen Arbeit outsourcen. Das macht jetzt nur noch die KI. Hört sich alles werbetechnisch immer gut an! Am Ende muss natürlich auch technisch geprüft werden. Funktioniert das ganze Thema überhaupt für uns? Ja und darüber hinaus gibt es natürlich auch viele weitere Themen wie die IT Sicherheit, weitere Compliance Themen. Also es ist ein ganz großes Paket und dieses große Paket von verschiedenen Fachbereichen muss irgendwie zusammengebracht werden in der Governance.

► Okay, dann gehen wir in den nächsten Block. Das Thema ist Zustand und Wahrnehmung. Da können Sie 2 bis 3 konkrete Anwendungsfälle benennen.

◄ Ja, klar. Also was wir jetzt machen, ist natürlich Microsoft Copilot. Das ist ein konkreter Anwendungsfall, oder wie präzise soll die Frage beantwortet werden? Dann halt. Genau. Also da geht es ja eher so ein bisschen

darum, die tägliche Büroarbeit zu erleichtern. Ja. Das heißt, ich lasse mir Texte schreiben, ich lasse mir Texte zusammenfassen, ich lasse mir Excel Tabellen zusammenfassen etc. Ich glaube, das ist ein Thema, das kann universal überall eingesetzt werden. Das ist kein hausgemachtes Thema, völlig klar. Ja, es gibt KI-Systeme, die sind relativ speziell auf irgendwelche Prozesse runtergebrochen und gehen dann auch tatsächlich nur in der Branche oder in dem Bereich. Das Thema Copilot, das ist ja ähnlich wie Chatgpt und und andere generative AI. Da geht es einfach darum, den Arbeitsalltag zu erleichtern. Das wollen wir jetzt einführen. Da haben wir jetzt schon eine erste Testphase durchgemacht. Da haben wir schon so ein paar Anwendungsfälle herausgearbeitet, die wir hier bei uns einsetzen wollen oder für die wir die KI einsetzen wollen. Das werden wir jetzt in Zukunft machen. Was wir halt noch haben, ist das Thema Adobe. Ich kenne jetzt nicht den speziellen Produktnamen, aber da geht es so ein bisschen darum, Bilder auszugestalten. Da wurde mir aus der Marketingabteilung auch gesagt, da gibt es über dieses Tool von Adobe die Möglichkeit, dass das Bild automatisch da irgendwie bildlich hergestellt wird. Also ich als Laie stelle mir das so vor: Der Rotlicht Ton wird dann sofort automatisch angepasst, ohne dass das menschliche Auge da irgendwie abgleichen muss. Und das sind so Tools, das sind so Anwendungsfälle, die wir jetzt aktuell auf dem Tisch haben.

► Okay, wie werden diese initiiert, freigegeben und auch betrieben später?

◄ Ja, also zum einen gibt es eine übergeordnete Arbeitsgruppe. Es gibt eine feste Instanz, die gesellschaftsrechtlich jetzt auch errichtet worden ist bei uns mittels einer Richtlinie. Dieses Gremium haben wir KI-Gremium genannt. Da sitzen Mitglieder aus verschiedenen Fachbereichen drin, wie IT, Sicherheit, Compliance, Datenschutz, IT allgemein etc. Und dieses Gremium soll quasi im Kollektiv freigeben. Das passiert mit einem fest etablierten Prozess. Das heißt, wir haben gewisse Punkte aus jedem Fachbereich, die wir für wichtig erachtet haben, die wir herausgearbeitet haben in den Fachbereichen. Die haben wir in Form einer Checkliste zusammengefasst. Das heißt beispielsweise für den Datenschutz Bereich kann ich sagen: Wichtig für uns ist, dass wir mit dem Anbieter, dessen KI wir nutzen, einmal so einen Auftragsverarbeitungsvertrag haben. Das ist ein relativ datenschutzrechtliche Thema. Für uns war wichtig, dass wir dieses Vertragswerk haben, weil wir unter Umständen auch rechtlich dazu verpflichtet sind, so eins zu haben und das auch verschriftlicht zu haben. Von daher ist das quasi ein Punkt aufseiten des Datenschutzbereichs, den wir in der Checkliste aufgeführt haben. Und wir gehen dann einmal diese

Checkliste durch. Ja, von A bis Z. Wenn jemand KI installieren will, stellt er quasi einen Antrag in diesem Gremium. Dafür gibt es einen festen Prozess über ein Ticketsystem. Dann wird einmal diese Checkliste abgearbeitet und wir können dann später entscheiden: Ja, wir wollen die KI einsetzen oder nicht?

► Okay, was läuft dabei gut und wo hakt es typischerweise?

◄ Gut, laufen ja immer Sachen, die pragmatisch und einheitlich sind aus meiner Sicht, das heißt die vorher festgesetzt sind, weil die dann für alle gleich sind. Ja, völlig logisch. Was natürlich immer fernab von so pragmatischen Prozessen ist, ist auch so ein bisschen die Diskussion. Das heißt, man muss über gewisse Tools auch fernab dieses festgefahrenen Prozesses reden können. Ja, manche Sachen muss man vielleicht noch mal erläutern. Manche können wir tatsächlich vielleicht nicht in dem Stadium einsetzen, in welchem sie bei uns beantragt worden ist, aber vielleicht können wir sie auch technisch limitieren oder gewisse Funktionen einfach gar nicht einsetzen, so dass es rechtlich und technisch dann auch legitim ist, das ganze Thema einzusetzen. Ich glaube, da müssen wir noch viel, viel Arbeit leisten, dass wir auch diskutieren über solche Themen, vor allen Dingen argumentativ wertvoll diskutieren. Das ist so das Thema, wo wir alle alle an einen Tisch müssen und da vielleicht noch ein bisschen nachjustieren müssen. Aber ansonsten denke ich, dass solche einheitlichen Prozesse eigentlich wegweisend sind.

► Machen wir weiter in dem Bereich Anforderungen und Governancebedarf. Also was sind aus deiner Sicht die wichtigsten Anforderungen an eine gute Governance von KI?

◄ Ja, das ist eine gute Frage. Also KI ist ja am Ende immer ein Thema, was mit Blick auf das Risiko ausgestellt werden muss. Das heißt, jede KI hat ein individuelles Risiko Das heißt, über jede KI muss man auch individuell sprechen können und diskutieren können. Völlig klar. So was macht für mich eine gute Governance aus. Das ist das, was ich gerade schon gesagt habe dass sie einheitlich ist, dass sie für alle gleich ist und dass sie pragmatisch nachvollziehbar ist. Das heißt, ich kann wirklich anhand fester Prozesse sagen: Okay, so läuft's. Die KI wurde jetzt freigegeben und die KI wurde jetzt vielleicht nicht freigegeben, weil diese Prozesse dahinter stecken. Zum einen ist es die Pragmatik am Ende, das heißt, man setzt ein Programm fest, man macht eine Checkliste fest. Das ist uns wichtig und daran halten wir uns auch. Und zum anderen muss man

natürlich alle Fachbereiche zusammenbringen. Das ist die größte Herausforderung. Man braucht ein Anforderungsprofil aus jedem Fachbereich und das muss man irgendwie zusammenfügen.

► Okay, wir gehen noch ein bisschen auf den Prozess an sich auch ein. Das heißt, es könnte durchaus sein, dass es noch mal sich wiederholt, vielleicht ein bisschen spezifischer zu werden. Welche Mindestprozesse oder Entscheidungspunkte werden denn benötigt? Also zum Beispiel vor dem Start überhaupt, um darüber zu sprechen von Go Life oder auch im Betrieb später.

◄ Ja, habe ich verstanden. Die Frage also natürlich mehrere Entscheidungsszenarien, sage ich mal. Das erste Entscheidungsszenario beginnt schon beim Einkauf. Das heißt, wir haben eine vorgefertigte Checkliste mit Dingen, die überhaupt eingekauft werden können. Und wenn sie eingekauft werden, dann muss natürlich auch vorher selektiert werden, was wir brauchen, welches Vertragswerk und solche Geschichten. Wir haben uns vorher darauf verständigt, welche KI wir gar nicht einsetzen wollen. Ein Beispiel wäre zum Beispiel KI, die für Manipulationen gedacht ist, ja, die man dafür auch einsetzen kann. Oder Social Scoring oder solche Geschichten. Das heißt, das ist ein absolutes KO-Kriterium auf so einer Checkliste innerhalb der Einkaufsabteilung, die wir erstellt haben. Das heißt, hier fällt schon die erste Entscheidung über KI ja oder nein. So, dann geht es weiter. Wir prüfen einmal nach dem Motto: Dürfen wir es einsetzen, wenn wir es nicht einsetzen? Und wir kommen dann im Rahmen unserer Checkliste, die wir im KI Gremium erarbeitet haben, auf den Nenner. Ja, es funktioniert. So, dann beginnt ja erstmal eine Testphase. Das heißt, es wird einmal getestet, ob das ganze Thema, so wie wir uns das ja auch vorstellen, ja fiktiv auch tatsächlich funktioniert. Das ist ja oft auch nicht der Fall. Denn oft denkt man, dass solche Sachen sofort funktionieren.
Aber die müssen ja auch irgendwie an die technischen Systeme angepasst sein. Das heißt, es gibt ein Proof of Concept. Wir prüfen einmal mit Testdaten. Wenn wir dann feststellen, es funktioniert nicht, dann haben wir ja quasi das zweite Entscheidungsszenario, wo wir sagen Geht nicht. Dann können wir immer noch ablehnen. So und dann kommt noch mal ein drittes Entscheidungsszenario: Nachdem wir das ganze Thema scharfgestellt haben, mit Produktivdaten bespielt haben. Und es funktioniert. Da müssen wir auch regelmäßig kontrollieren. Es ist jetzt nicht so, dass wir das Thema einfach dann laufen lassen und es ist alles erledigt, sondern wir gucken uns das Thema immer regelmäßig an. Mit regelmäßig meine ich, das ist so ein bisschen davon abhängig, welches Risiko und welcher

tatsächliche Anwendungsfall mit der KI vollzogen wird. Bei Copilot müssten wir da echt wirklich immer quartalsweise draufgucken und gucken, ob es da Änderungen gibt. Es gibt ja auch Updates von Microsoft und sowas und darauf müssen wir reagieren und das Risiko immer immer wieder neu beziffern und diese ganzen Themen einfangen. Das heißt, über so einen Kontrollmechanismus ja finden auch nach Rollout der KI immer wieder neue Entscheidungen statt und wir entscheiden dann auch im Zweifelsfall, dass es dann abgestellt werden muss, wenn es zu risikoreich wird.

► Welche Nachweise, Metriken oder Dokumente brauchen wir denn, um im Endeffekt die KI auch freizugeben oder dann eben auch weiter benutzen zu können?

◄ Welche Nachweise? Wir brauchen erstmal einen Vertrag, ein Vertragsverhältnis in irgendeiner Form. Das brauchen wir auf jeden Fall mit dem Anbieter. Was brauchen wir noch? Zertifikat und so. Natürlich auch nicht verkehrt. Gibt es ja auch bei so IT-Dienstleistern. Eigene Nachweise. Wir prüfen natürlich. Ein Proof of Concept ist ja auch am Ende ein Nachweis für uns später zusammen. Wenn in der Produktivphase, also wenn wir ein System scharf geschaltet haben und es ist irgendwas passiert aus technischen Gründen, zum Beispiel: Ich habe die KI, die jemanden diskriminiert. Ja, weil der Algorithmus da irgendwie so reagiert hat. Ich kann aber nachweisen, wir haben eine schöne Testphase gehabt. Es hat alles funktioniert Wir haben viele Szenarien durchgespielt, es ist im Nachgang passiert, dann kann ich mich da auch so ein bisschen immer von der Schuld befreien, sage ich mal, indem ich sage Okay, wir haben es ja, wir haben es so durchprobiert, es hat funktioniert. Das ist jetzt ein Einzelfall, korrigieren wir direkt und das Thema ist durch. Das heißt, ich meine am Ende die Nachweise, die wir brauchen, um das ganze Thema funktioniert, die erschaffen wir uns im Regelfall selber. Natürlich nehmen wir auch Nachweise von den ganzen Dienstleistern, die wir bekommen können. Die helfen sicherlich auch. Aber am Ende müssen wir selber für Nachweise sorgen.

► Wer sollte aus deiner Sicht in den gesamten Prozess eingebunden sein?

◄ Für die Errichtung einer Governance.

► In der Governance an sich auch.

◄ Ja, am Ende ist es ja jeder Mitarbeiter, also jeder Mitarbeiter, der irgendwie in irgendeiner Form mit KI zu tun haben wird. Das heißt, er ist Nutzer, nutzt die KI selber, überwacht die KI oder kauft die KI ein. Alles, was damit zu tun hat, das heißt jeder Mitarbeitende in der in der Sequenz auf jeden Fall.

Dann natürlich die Führungskräfte, die vielleicht noch mal einen Stepp weiter. Die müssen natürlich wissen, dass wir das Thema bei uns reguliert haben, reglementiert haben, dass wir mit KI arbeiten wollen und worauf zu achten ist. Ich glaube, da hört es auf.

► Dann nehmen wir das Thema Risiken und Herausforderungen insgesamt von KI. Welche Risiken siehst du im Zusammenhang mit KI aus deiner fachlichen Perspektive?

◄ Ja, da gibt es eine Menge. Also was ja immer schwierig ist, das Thema KI allgemein, fachlich, mathematisch zu erklären. Ja klar gibt es einen Algorithmus, der Muster hat, keine Frage. Und den kann man sicherlich auch wiedergeben und das erklären. Aber man gibt ja am Ende Daten rein in eine KI und da kommt irgendwas raus im Regelfall. Oder die KI arbeitet ja selbstständig autark. Ja, das ist ja, ich sage mal, ein Merkmal einer KI Und man kann nie ganz so vorhersagen, dass alles, alles wirklich korrekt läuft. Von daher Ich glaube, das ist das größte Risiko, dass man KI am Ende nicht wirklich erklären kann. Und was man nicht erklären kann, birgt immer irgendwelche großen Gefahren. Ansonsten ein Risiko bleibt auch immer, dass nicht alle Bescheid wissen. Da müssen wir natürlich nachrüsten und und nachjustieren. Jeder Mitarbeiter muss da geschult werden, völlig klar. Ähnlich wie bei Staubsaugern sage ich immer: Der Staubsauger von Bosch hat eine andere Betriebsanleitung als der von Siemens. Das heißt, wir müssen da individuell schulen, dass jeder auch wirklich das Thema versteht und mit der KI am Ende umgehen kann.

► Wo siehst du potenzielle Zielkonflikte, also zum Beispiel zwischen Datenschutz, Security und der Innovationsfähigkeit oder auch zwischen IT Datenschutz? Gibt es da mögliche Zielkonflikte?

◄ Ja, also Datenschutz und KI Verordnung geht ja so ein bisschen nebeneinander her. Beide sind also da DSGVO und KI Verordnung, sage ich mal. Beide haben rechtlich ähnlichen Mechanismus, also risikobasiert aufgebaut. Dennoch stehen sie sich so nicht im Weg. Eigentlich laufen also, ergänzen sich mehr oder weniger. Aber es kann natürlich hier zu Konflikten kommen Da wo beispielsweise das Datenschutzrecht sagt ja, geht nicht, aus datenschutzrechtlichen Gründen. Ja, da werden Daten eingespielt, sagt die KI Verordnung unter Umständen. Bei uns geht es schon. Also das weiß ich so ein bisschen aus rechtlicher Natur, sage ich mal in manchen Fällen. Dann haben wir auch natürlich zum Beispiel im Datenschutz eine ganz andere Markt Überwachungsbehörde im Hintergrund. Da haben wir einmal die Datenschutzbehörden. Und bei dem Thema KI

und der KI Verordnung haben wir die Bundesnetzagentur. Das kann natürlich am Ende auch ein Risiko sein, dass zwei Behörden an verschiedenen Stellen das Thema bewerten. Das heißt, die eine gibt es vielleicht frei, die andere nicht. Das wäre ja auch fatal. Am Ende muss man halt immer gucken. Also es gibt Sachen, die sind aus rechtlicher Sicht dann vielleicht nicht so ganz konform. Da sagt aber die IT selber für uns, für uns ist das kein Problem, das kann funktionieren. Von daher. Also ich glaube, das ist immer also Zielkonflikt ist immer so eine Sache. Ich glaube Datenschutz und KI ist so das Thema, wo wir aufs Gleiche hinsteuern, aber ein verschiedenes Ergebnis haben können am Ende. Das ist so das einzige, würde ich sagen.

► Okay. Was müsste vermieden werden, damit eine Governance Struktur tatsächlich funktioniert?

◄ Was müsste vermieden werden, damit eine Governance Struktur tatsächlich funktioniert? Das ist eine gute Frage. Was müsste vermieden werden, damit eine Governancestruktur tatsächlich funktioniert. Das ist eine gute Frage. Keine Antwort zu.
Was müsste vermieden werden? Also, Sicherheitsvorfälle sollten vermieden werden, würde ich sagen. Also, wenn ich über das Thema nachdenke, dann fällt mir eigentlich in erster Linie immer das Thema IT Sicherheit ein. Ja, wir müssen ja irgendwie schaffen, dass wir gute Datensätze haben, qualitativ hochwertige Datensätze haben, weil die KI arbeitet ja im Regelfall mit Datensätzen. Das heißt, wir müssen diese Datensätze ordnungsgemäß absichern. Und das setzt natürlich voraus, dass wir ein gewisses Berechtigungskonzept haben etc. Das heißt, wenn ich da eine Datei habe auf die jeder zugreifen kann, weil das Berechtigungskonzept nicht richtig ist. Dann kann am Ende die KI auch darauf zugreifen. So, das heißt, wir müssen auf jeden Fall vermeiden, dass wir offene Berechtigungsstrukturen haben, dass nicht geregelt haben, dass wir zu viele Lücken für IT Sicherheitsvorfälle haben. In der Hinsicht ja. Also beim Thema vermeiden ist für mich immer Datenqualität muss sauber sein und wir müssen vermeiden, dass unsere IT Sicherheit angegriffen wird.

► Wie gehen wir mit Anbieter Dokumentation, also sowas wie Model Cards um? Datenherkunft oder eben auch sowas Intellectual Property?

◄ In erster Linie machen wir uns Gedanken. Das muss einmal vorgeschaltet sein. Viele machen sich ja nicht mal Gedanken. Wir machen uns Gedanken. Wir versuchen, das ganze Thema zu separieren. Also man muss

natürlich erst mal feststellen, wo kommen die Daten her, die hier reinfließen? Da gibt es mehrere Quellen. Zum einen hat man natürlich das freie Internet, was wahrscheinlich der größte Baustein ist und dann hat man natürlich auch Unternehmensdaten. Im Regelfall die Unternehmensdaten, die man auch selbst einsehen kann als Mitarbeiter. Das heißt als Beispiel, wenn ich Mitarbeiter der HR Abteilung bin, da habe ich eine ganz andere Einsicht auf Datensätze als Mitarbeiter aus der Logistikabteilung. So, das vielleicht einmal vorab und wenn ich dann einmal diese Datenquellen habe, also diese beiden, die ich ohnehin sehen kann. Das heißt, meine Dokumente, meine PDF Dokumente, meine Excel Tabellen ja auch bestückt mit Unternehmensdaten und das freie Internet. Ja und ich kann diese beiden Datensätze separieren, aber trotzdem in die KI einfließen lassen. Dann habe ich schon viel gewonnen. Dann glaube ich, dass man da schon sehr konforme Züge annehmen kann.

► Was brauchen wir von Anbietern der IT oder auch Prozessverantwortlichen, um Entscheidungen treffen zu können?

◄ Wir brauchen natürlich eine gute Informationslage. Völlig klar. Also da macht es natürlich Sinn, vorher sich zu überlegen: Welche Daten brauchen wir? Welche Informationen brauchen wir, um Entscheidungen treffen zu können? Jede KI muss immer individuell betrachtet werden. Mit Blick auf die Anwendungsszenarien und dann auch mit Blick auf das ausgehende Risiko. Das heißt, wir können nicht einfach pauschal sagen so, hier ist ein Ampelsystem und wir hauen das da jetzt einmal rein und dann kommt irgendwie ein Ergebnis raus, sondern wir müssen ja immer individuell Bewerten und wahrscheinlich unter Umständen auch diskutieren. Das heißt, das was wir, das ich von diesen Instanzen erwarte, ist einfach, dass wir eine geballte Informationslage bekommen, die wir vorher auch irgendwie in einem Rahmen festgelegt haben. Das heißt, wir als Gremium, als Gremium sitzen fest. Okay, wir müssen aber wissen, wo der Anbieter sitzt. Wir müssen einmal wissen, was für Strukturen der Anbieter hat, also gesellschaftsrechtliche Strukturen. Wir müssen einmal wissen, was, was das Produkt kann etc. pp. Also es ist eine lange Liste mit mit Vorabinformationen, die quasi Prozessverantwortliche und auch die die Einkaufsabteilung einmal vorher abfragen muss, uns zur Verfügung stellen muss. Und wenn wir diese Informationslage haben, dann können wir auch entscheiden okay.

► Welche Erfahrungen haben wir mit Gen-AI-Tools? Also in Richtung Kennzeichnung, rechte Informationspflichten oder sonstige Vertragsklauseln?

◀ Gegenwärtig ist mir noch nichts irgendwie über den Weg gelaufen. Was ich schon mal gelesen habe, bei uns sind Verträge, wo drinsteht, wir spielen gewisse Daten in KI Systeme ein. Da geht es vielleicht um E-Learning oder andere Sachen. Ist jetzt nur ein Beispiel. Ja, das ist nicht so, aber in ähnlicher Form. Und da sind manchmal solche, solche Sachverhalte verklausuliert, wie zum Beispiel wir nehmen die Daten und spielen in unsere KI Systeme ein und machen daraus irgendwas Ja, das kann mal vorkommen, ist aber bis jetzt noch nicht ganz so präsent. Wenn man ehrlich ist und wir selber? Ja, wir setzen bis jetzt noch nicht so viel KI ein.

▶ Okay, jetzt geht es ein bisschen in Richtung Ressourcenkompetenzen im Unternehmen, auch wo fehlenden Ressourcen oder eben auch Kompetenzen aktuell im Bereic vielleicht Schulungen? Wie sieht es da aktuell aus?

◀ Ja, den Bereich Schulung den würde ich hervorheben bei dem ganzen Thema. Einfach aufgrund dessen, weil das Thema so neu ist. Das Thema KI ist ja nicht wirklich neu, aber es ist jetzt medial so hochgekommen und es gab einfach Fortschritte, auch durch diese gesetzgeberischen Entwicklung. Von daher muss man einfach sagen, das Thema ist jetzt einfach präsent. Das Thema will jetzt einfach genutzt werden. Also KI will genutzt werden in Unternehmen, in Konzernen und viele, viele wissen nicht, was KI ist und wie es einzusetzen ist. Das heißt, ich glaube, das Thema Schulung ist so ziemlich das Wichtigste und da fehlen einfach die Ressourcen am Ende, weil es muss ja einen geben, der auch wirklich schult, der auch maßgeschneidert schult, das heißt sich ein E-Learning einzukaufen irgendwo mit allgemein Lerninhalten macht aus meiner Sicht wenig Sinn. Aber es macht wirklich Sinn, sich zu überlegen was wollen wir im Konzern machen mit der KI? Welche KI wollen wir einsetzen und wie können wir bestmöglich schulen, dass wirklich jeder Mitarbeiter am Ende eine gewisse KI Kompetenz aufbringt, die auch relevant ist für seine tägliche Arbeit mit KI? Das ist aus meiner Sicht der größte Baustein, das größte Thema, wo Ressourcen fehlen. Das sind gar nicht monetäre Ressourcen aus meiner Sicht, sondern eher zeitliche Ressourcen. Ja, man muss das ganze Thema einmal aufrollen. Das Thema KI an sich. Also ich glaube, dass das das bringt nicht so viele Ressourcen mit Was natürlich immer wichtig ist, ist das Thema Technik dahinter. Man muss KI auch irgendwie integrieren können, man muss auch kontrollieren können. Dafür braucht man ja stetig Ressourcen. Da braucht man Mitarbeitende, die vom Fach sind und auch immer irgendwie mit dabei sind. Das hat sicherlich dann auch eine monetäre Komponente. Kostet halt Geld. Aber

das will ja auch die KI-Verordnung am Ende, das heißt, das ist auch gesetzgeberisch vorgeschrieben. Das heißt, das sind so Ressourcen, die müssen wir halt auch einfach einhalten. Also für mich einmal Platz eins ist das Thema Schulungen, da müssen wir nachjustieren. Platz zwei ist ganz klar das Thema Kontrolle von KI. Das ist wirklich nicht einmal ausrollen und dann laufen lassen, sondern wirklich regelmäßig zu kontrollieren und auch immer State of the Art zu sein.

► Hat so ein bisschen schon die zweite Frage beantwortet, welche Schulungen, Guides oder Checklisten eben helfen könnten?

◄ Ja, da gibt es ein spannendes Hinweispapier von der Bundesnetzagentur. Das kann man sich angucken. Also da wird einmal gefragt, wie so eine KI-Kompetenz ist. Ich will auch gar nicht zu sehr ins Rechtliche gehen, aber es ist ja eine Vorgabe der KI Verordnung, dass die Mitarbeitenden oder die User von KI quasi eine gewisse KI Kompetenz aufbringen. Man kann da wie gesagt jetzt nicht eine Schwarz schwarz Weiß Lösung anbieten, indem ich sage ich hole da jetzt einmal ein E-Learning Kurs. Der dauert 30 Minuten. Dann werden einmal die Basisinhalte abgearbeitet und jeder Mitarbeitende hat eine KI-Kompetenz, die ausreichend ist für eine KI. Das wird nicht funktionieren. Das heißt, mit Blick auf Guidelines oder irgendwelche Leitplanken, die man setzen kann, ist einfach zu sagen wir müssen schulen und wir müssen individuell schulen. Bedeutet, wir gucken uns das System an, beispielsweise Wir haben eine KI, die in die Kategorie der Hochrisiko reingeht. Das heißt eine KI, die ein hohes Risiko hat. Am Ende sage ich mal für die Rechte und Freiheiten des Menschen. Da müssen wir natürlich auch viel, viel mehr Ressourcen aufbringen und intensiver schulen, dass diese KI Kompetenz dann später auch in einem ordnungsgemäßen Umfang vorhanden ist. Das heißt, mit Blick auf Leitplanken oder Guidelines ist es einfach wichtig invidiuellzu schulen.

► Was sollte vermieden werden, damit Governance nicht blockiert?

◄ Das ist auch wieder eine gute Frage mit vermieden. Ja, ich glaube, man muss zum einen erst mal einen Grundtenor festlegen. Also was wollen wir machen mit dieser Governance? Und wir wollen am Ende wollen wir ja KI ermöglichen im Konzern, wir wollen ja Chancen liefern. Wir wollen KI in unseren Arbeitsalltag integrieren. Und wir wollen vor allen Dingen auch wettbewerbsfähig bleiben und sein. Das ist vielleicht noch mal ganz wichtig zu sagen also wir wollen nicht KI kaputt regulieren am Ende. Das jeder irgendwie sich in der Vertragsmathematik verliert, sage ich mal am

Ende und wir über Klauseln reden. Und das geht nicht um das geht nicht, sondern in erster Linie wollen wir KI durch so eine Governance möglich machen und jedem Mitarbeiter ein vertrauensvolles Gefühl geben, transparentes Gefühl geben, dass wir es verantwortungsvoll nutzen wollen in unserem Konzern. Das ist vielleicht noch mal ganz wichtig.
Ich glaube, am Ende ist wichtig, dass wir genau zum einen diesen Grundtenor haben. Wir wollen das ganze Thema ermöglichen und uns nicht in diesem Kleinkarierten verfangen. Das ist, glaube ich, das Entscheidende, was ich sagen wollte. Also wirklich nicht irgendwie. Wir haben jetzt 50 Klauseln in einer Richtlinie. Die müssen alle eingehalten werden, sondern ich habe vorher fünf Punkte aufgelistet nach dem Motto, das sind die Möglichkeiten, die wir durch diese Richtlinie jetzt ermöglichen wollen. Ja, wir wollen KI möglich machen und so schaffen wir es, glaube ich auch, wenn wir anfangen, jetzt irgendwie alles zu verklausulieren und das geht nicht, dann werden wir, glaube ich, so eine Governance vermeiden.

► Okay, jetzt noch ein bisschen spezifischer. Welche datenschutzrechtlichen Herausforderungen siehst du bei KI Anwendungen an sich?

◄ Natürlich. Zurückzuverfolgen, was mit den Daten passiert. Das ist ja mal ganz spannend. Wir als Verbraucher, sage ich mal oder wir als ganz normale Bürger eines EU Mitgliedstaat haben ja so sogenannte Betroffenenrechte im Datenschutz. Ja, das heißt beispielsweise habe ich das Recht auf Auskunft. Also ich als EU Bürger darf immer beim Unternehmen anfangen und sagen Könnt ihr mal, könnt ihr mir bitte sagen welche personenbezogenen Daten ihr von mir habt. Und da sehe ich das größte Problem, weil eine KI zu fragen, welche Daten da jetzt vorhanden sind, wird schwierig, denn da werden ja selber noch mal neue Daten generiert. Ja und ich kann auch nicht den ich sag mal, die Chronologie dieser Datenerzeugung kann ich auch nicht wiedergeben. Ja, das heißt, falls jemand mal anfangen sollte ja, ich möchte meine Rechte geltend machen. Wird schwierig, das wirklich zu 100 % transparent Auskunft zu können. Das ist aus datenschutzrechtlicher Sicht das größte Risiko.

► Okay, gibt es aus deiner Sicht Fallstricke bei der Bewertung von Transparenz, Zweckbindung oder eben auch der Datenminimierung im Bereich KI?

◄ Ja, genau, das ist ja Transparenz. Auf jeden Fall ist ein Fallstrick. Man kann ja nicht zurückverfolgen, was wirklich passiert mit den Daten, wo die Daten hergekommen sind. Das ist immer, immer schwierig. Zweckbindung ist immer so eine Sache, darüber philosophiere ich auch immer. Beziehungsweise haben wir das Thema auch oft diskutiert. Wichtig ist natürlich, dass

wir KI einsetzen, mit einem gewissen Zweck. Das heißt also, wenn wir uns uns zum Beispiel ganz plastisch das Thema Copilot angucken, dann macht es natürlich Sinn, dass man konkrete Anwendungsfälle einmal für sich deklariert und die auch auflistet und dann auch den Mitarbeiter sagt Bitte nur dafür nutzen. Weil am Ende haben wir eine KI, eine generative KI, die wir zur Verfügung stellen und da kann ja jeder alles mögliche mitmachen, jede Datensätze reinspielen, prompten wie er will und da müssen wir so ein bisschen aufpassen. Von daher glaube ich, man muss das so ein bisschen gezwungen machen. Und so eine Zweckbindung ist dann immer sehr konkret, wenn man sagt okay, wir haben ja Anwendungsfälle und die KI darf wirklich nur für diesen Zweck eingesetzt werden. Ja, man kann natürlich anders formulieren, indem man sagt hier, wir haben jetzt Copilot und setzen wir ein für den Arbeitsalltag relativ weit formuliert. Das heißt, der Mitarbeiter kann dann am Ende fast alles da eingeben, weil alles ja irgendwie so ein bisschen relevant ist für seinen Arbeitsalltag. Deshalb glaube ich, dass man da ein bisschen dezidierter formulieren muss am Ende. Okay.

► Das sind soweit alle meine Fragen. Gibt es sonst noch Aspekte, die du für besonders relevant hältst, die wir noch nicht angesprochen haben?

◄ Für besonders relevant? Ich glaube, am Ende ist es wichtig, mit Blick auf die Governance, dass man das generisch und gesund in einem Konzern aufzieht, nicht mit einem Hauruckverfahren und schon gar nicht mit vorgefertigten Schablonen von irgendwelchen Dienstleistern oder Kanzleien. Ich meine, das Angebot auf dem Markt ist groß. Ich glaube, es ist wichtig, dass man sich Gedanken dazu macht: Was wollen wir wirklich machen mit KI? Wo verpassen wir vielleicht wirklich den Wettbewerb? Wo können wir vielleicht uns weiterentwickeln, auch technisch mit KI und uns vielleicht auch dem Wettbewerb gegenüber verbessern? Man sollte sich einmal hinsetzen und sich da mal wirklich ernsthaft Gedanken machen, mit vielen verschiedenen Fachabteilungen auch sprechen. Wo wollen wir hin? Ist es wirklich nur diese generative KI nach dem Motto: Ich gebe da irgendwie zwei, drei Stichworte ein in die KI, da kommt ein Text raus, den kann ich nutzen. Sicherlich auch vorteilhaft. Aber was ich damit sagen will, ist einfach man muss viel über das Thema reden. Man muss mit allen Fachabteilungen einmal einen Konsens haben und dann muss man auch im laufenden Prozess muss man immer wieder Gespräche führen und das Thema immer wieder präsent halten. Weil ich glaube, wir stehen vor einer großen Zeitwende, was das angeht. Also wir werden einfach viel mit KI arbeiten werden. Von daher müssen wir uns auch zwangsläu-

fig und mit müssen meine ich wirklich jeden Mitarbeiter. Also es muss sich jeder Mitarbeiter mit dem Thema beschäftigen. Von daher ich glaube, wichtig ist, dass man einfach kommuniziert. Natürlich von zentraler Stelle von der Unternehmenskommunikation aus, aber auch untereinander viele Gespräche führt und insbesondere auch die Mitarbeitenden abholt, die vielleicht weniger Berührungspunkte mit dem Thema haben.

► Okay, danke schön. Kann ich dich bei Rückfragen noch mal kontaktieren?

◄ Ja, klar.

Literaturverzeichnis

Batool, Amna, Didar Zowghi und Muneera Bano (2023). *Responsible AI Governance: A Systematic Literature Review*. URL: http://arxiv.org/abs/2401.10896 (besucht am 01. 06. 2025). Vorveröffentlichung.

Choung, Hyesun, Prabu David und John S. Seberger (2023). *A Multilevel Framework for AI Governance*. URL: http://arxiv.org/abs/2307.03198 (besucht am 17. 08. 2025). Vorveröffentlichung.

European Comission (2025). *Ethics Guidelines for Trustworthy AI | Shaping Europe's Digital Future*. URL: https://digital-strategy.ec.europa.eu/en/library/ethics-guidelines-trustworthy-ai (besucht am 13. 06. 2025).

European Parliamentary Research Service (2024). *Artificial Intelligence Act*.

ISO (2025). *ISO/IEC 42001:2023(En), Information Technology — Artificial Intelligence — Management System*. URL: https://www.iso.org/obp/ui/en/#iso:std:iso-iec:42001:ed-1:v1:en (besucht am 13. 06. 2025).

Khatri, Vijay und Carol V. Brown (2010). „Designing Data Governance". In: *Communications of the ACM* 53.1, S. 148–152.

Kim, Byeong-Je, Seunghoo Jeong, Bong-Kyung Cho und Ji-Bum Chung (2025). „AI Governance in the Context of the EU AI Act: A Bibliometric and Literature Review Approach". In.

Mäntymäki, Matti, Matti Minkkinen, Teemu Birkstedt und Mika Viljanen (2025). *(PDF) Putting AI Ethics into Practice: The Hourglass Model of Organizational AI Governance*. ResearchGate. URL: https://www.researchgate.net/publication/361023169_Putting_AI_Ethics_into_Practice_The_Hourglass_Model_of_Organizational_AI_Governance (besucht am 01. 06. 2025).

National Institute of Standards and Technology, U.S. Department of Commerce (2025). *AI Risk Management Framework*.

Rai, Arun, Panos Constantinides und Saonee Sarker (2019). „Next-Generation Digital Platforms: Toward Human-AI Hybrids". In: *MIS Quarterly* Volume 43 (Issue 1), S. iii–X.

Veale, Michael und Frederik Zuiderveen Borgesius (2021). „Demystifying the Draft EU Artificial Intelligence Act". In: *Computer Law Review International* 22.4, S. 97–112.

Weill, Peter David und Jeanne W. Ross (2004). *IT Governance: How Top Performers Manage IT Decision Rights for Superior Results | MIT CISR*.

Eidesstattliche Erklärung

Stelzer, Nick Ansgar

Name, Vorname // Name, First Name

Ich erkläre hiermit, dass ich meine Seminararbeit mit dem Titel

Governance von Künstlicher Intelligenz: Eine vergleichende Analyse bestehender Modelle zur Gestaltung unternehmensinterner KI-Steuerung

selbständig und ohne fremde Hilfe angefertigt habe, und dass ich alle von anderen Autoren wörtlich übernommenen Stellen wie auch die sich an die Gedankengänge anderer Autoren eng anlehnenden Ausführungen meiner Arbeit besonders gekennzeichnet und die Quellen zitiert habe.

Südkirchen, den 25. August 2025

Ort, Datum, Unterschrift // Place, Date, Signature